

클라우드보안 컨설팅 실무

1. 클라우드보안 개요 (1p)
2. 클라우드보안 아키텍처 정의 (9p)
3. 클라우드 기술적 취약점 분석·평가 (18p)
4. 클라우드보안 마스터플랜 수립 (25p)

[별첨.1] 책임공유모델(Shared Responsibility Model) (33p)

[별첨.2] AWS Native 서비스의 ISMS 항목과의 연계성 (36p)

[별첨.3] 클라우드 보안 관제 (40p)

[별첨.4] 보안솔루션 이전 적용성 검토 (42p)

[별첨.5] 클라우드 보안성검토 기준 (43p)

2024.10.
컨설턴트 장성일



Cloud Computing

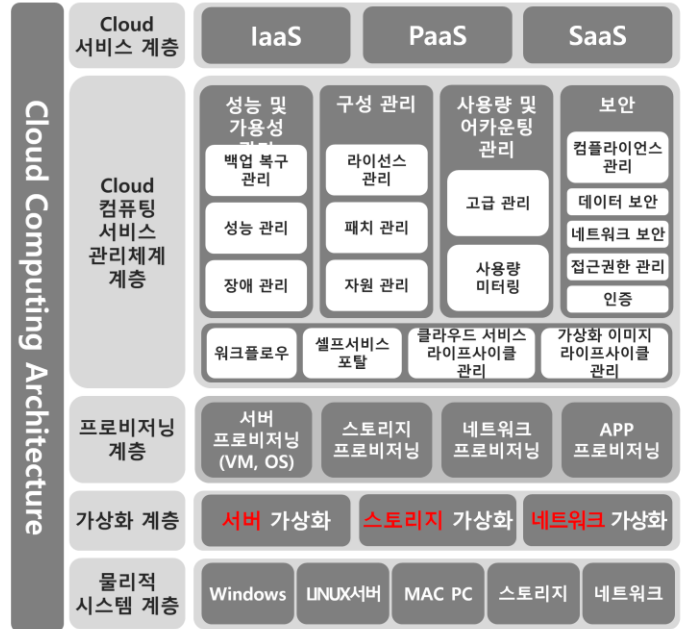
- 정의: 서버, 스토리지, 데이터베이스, 네트워크, 소프트웨어 등의 컴퓨팅 서비스를 공유 네트워크(“Cloud”)를 통해 제공하는 것
- 목적: 비즈니스 규모에 맞춰 합리적인 비용으로 비즈니스 서비스를 효율적으로 운영할 수 있도록 환경 제공

Cloud Computing 주요 특성

구분	설명
On-demand self-service	- 고객은 제공사의 도움 없이 필요에 따라 자동적으로 서버 시간과 네트워크 저장소와 같은 컴퓨팅 기능을 단독으로 준비할 수 있음
Broad network access	- 모든 기능들은 네트워크를 통해 이용 가능함 - 이기종 클라이언트 플랫폼(예: 모바일폰, 태블릿, 노트북, 워크스테이션)에서 접근 가능함
Resource pooling	- 고객 요구사항에 따라 물리/가상화된 자원들을 멀티 테넌트 모델을 사용하는 복수의 고객들에게 제공하기 위해 공유 관리함 - 고객이 제공하는 자원의 정확한 위치에 대한 정보 없이 장소 독립적으로 운용 가능함
Rapid elasticity	- 기능은 탄력적으로 준비되고 배포 가능함 - 자동으로 요구에 비례하여 빠르게 규모를 확장 또는 축소 가능함 (Auto Scaling)
Measured service	- 서비스 유형: 저장소, 프로세싱, 대역폭, 활성계정 등에 맞춰 측정 기능을 활용하여 리소스를 자동으로 제어하고 최적화함 - 자원 사용은 감시, 제어, 보고되어 서비스 이용자와 제공자 모두에게 투명성을 제공함

※ 출처: The NIST Definition of Cloud Computing(NIST, 2011)

Cloud Computing Architecture



※ Check Point

- Cloud : 빌려 쓸 수 있는(tenantable) SW 체계를 쉽게 접근 가능하도록 구현해 놓은 통합 인프라 플랫폼
- 빌려 쓰는 SW 개념의 연원
 - . On premise – ASP – SaaS – **Cloud**
 - (테넌트별 독립HW) (**가상화, Software defined tech.**)
- Cloud vs 가상화, 우리회사는 서버 가상화를 사용하고 있는데 굳이 Cloud를 써야 하나요?
- 가상화: 서버 / 스토리지 / 네트워크 / APP / Desktop (e.g. VMWare Horizon – Cloud PC)

Cloud 서비스 배포 모델

□ 모델 유형

- Cloud 서비스 배포 모델 유형은 Cloud 배포 장소와 서비스를 제공/사용 하는 주체에 따라서 **Public Cloud / Private Cloud / Hybrid Cloud / Multi Cloud(멀티 Cloud)**로 구분됨
※ DaaS, CaaS 등 서비스 유형 모델과는 구분하여 사용해야 함

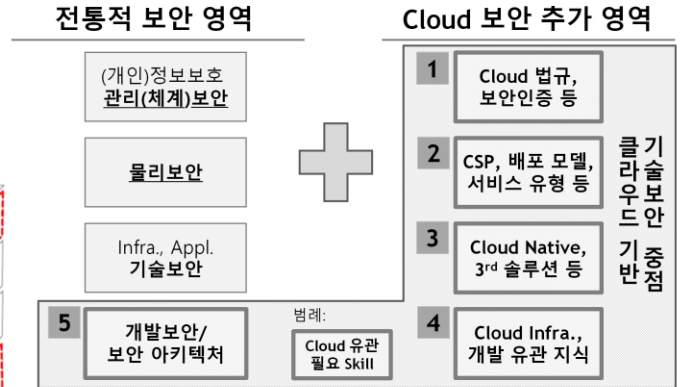
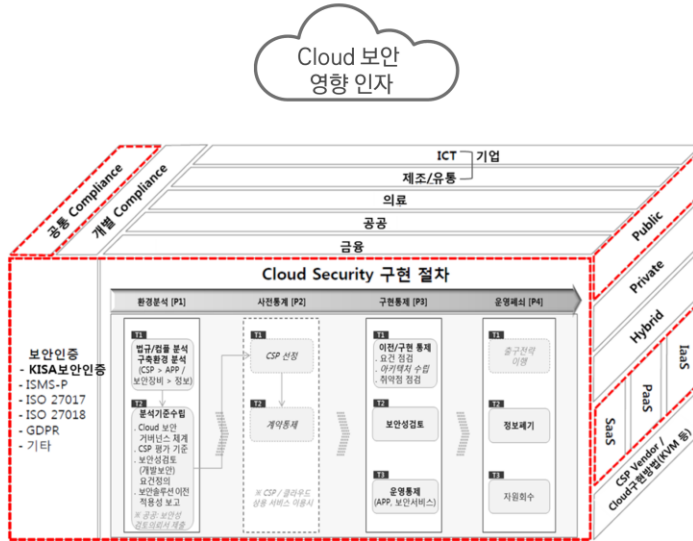
구분	Public Cloud	Private Cloud	Hybrid Cloud	Multi Cloud
특징	- 다수의 대중을 위하여 인터넷 기반으로 운용 - Cloud 인프라가 이용자 예겐 추상화되어 단순하게 보임(e.g. S3) 책임 공유 모델 	- 대외에 오픈되지 않고 내부망 위주로 운용 SDDC (SDC/SDN/SDS/Restful API 등) ※ HCI (Hyper-Converged Infrastructure) ※ OpenStack ⇒ VMWare	- Public + Private Cloud - Public + On-prem.을 결합하여 운용 ※ On-prem. 상면(IDC등) + CSP's Cloud SW 구축 ⇒ AWS OutPost, Az Stack, NCP Neurocloud, NHN Private Deck 등	- 멀티 Public CSP로 구성하여 운용 - On-prem. 연계성이 hybrid 대비 상대적으로 다소 약한 니앙스 포함
장점	- 규모의 경제를 통한 비용 관리 (전략적 결정) - 이용한 만큼 지불 - 서비스 구현 속도 향상 - 높은 수준의 탄력성 - 손쉽게 이용 가능한 고품질 응용 프로그램	- 보안 및 신뢰성 제고 PaaS 구축 및 운영 - 네트워크 대역폭, 인터넷 접속 제약 없음 - 서비스 수준 합의/관리 (SLA : Service Level Agreement / Mgmt.) 인프라 관리 편리성	- Public Cloud와 Private Cloud의 이점 활용 (AWS - VMware 연계) - 높은 수준의 유연성 - 다양한 배포 옵션 제공 - 탈출 계획 이행 유리	- 고 가용성 - 높은 수준의 유연성 - 업체 종속성 탈피 - 비용 효율성 - 탈출 계획 이행 유리
단점	- Cloud 서비스 제공자에 대한 통제 권한 부족 - Private Cloud에 비해 상대적으로 취약한 보안 (인터넷, 하드웨어 공유 문제 등)	# Public Cloud 대비 - 장비, 하드웨어 비용 ↑ - 가상화 기술 비용 ↑ - 상대적 낮은 탄력성 - 운용이 복잡함 ↑	- Public Cloud와 Private Cloud간 연계 시 보안 통제의 어려움 - 높은 구축 비용 및 운용의 어려움 - 네트워크 구성이 복잡함	2개 이상의 Cloud 제품을 사용하므로 운용이 복잡하고 어려움 (기술, 인력 이슈)

※ Checkpoint

- 배포 모델: 서비스가 어느 위치에서 제공되는가를 기준으로 모델을 구분함
- 서비스 모델: OO as a Service 로서, OO에 대해서 임대하여 사용할 수 있는 서비스 체계를 모델 구분의 기준으로 삼음. 예> IaaS / PaaS / SaaS / DaaS / Container as a Service
- Public 유형: 빌려쓸 수 있는(tenantable) SW 체계가 Private 대비 훨씬 우수
. e.g. AWS SageMaker (AI서비스)를 private에서는 직접 구현해야 함
- Private 유형이라도 미터링(과금) 체계를 고려해야 함. 자회사/관계사/지주사에 대한 과금 체계도 고려해야 하기 때문임

1. 클라우드보안 개요 (3/6) – 고려사항

- 클라우드보안은 고려해야 할 요소가 많아, **이용자 사업/IT 환경에 맞는 선택과 집중**이 필수적임. (인력 수급 이슈 포함)
- IT인프라(네트워크, 서버, AI 등 특정 SW 서비스 등), 개발 플랫폼 서비스, 응용 서비스가 가상화되고 집적됨.
 - 준비사항: IT-Cloud인프라 / 개발 / 정보보안솔루션 + CSP Native Service / 보안아키텍처·개발보안·보안성검토 지식
 - **5개 이상의 factor** (법규·산업군, 배포 모델, 서비스 모델, CSP/vendor별, 보안인증 등)가 영향을 미치므로, 고려요소 (체크리스트, 가이드, 아키텍처 등) $F_1 \times F_2 \times \dots \times F_5$ 가 될 수 있음.



서비스 모델 별 필요 역량 예시

- IaaS ⇒ CSP/Vendor별 인프라 특성
- PaaS ⇒ 개발보안, 개발 Infra (DevOps)
- SaaS ⇒ CSP로의 SaaS 보안 인증

※ Check Point

- 클라우드보안이 어려운 이유?
- 클라우드보안 인재 구하기가 어려운 이유?
- ☞ 기업 보안 담당자를 위한 Comment ~ !!
- 클라우드보안에 대한 전체 파악과
- 당면한 과제의 개념, 논리적인 수준으로 지식 습득
⇒ 클라우드보안 협력사와 협업이 가능한 수준
- 세부 업무 이슈들은 Spot 성으로 처리
- 지식의 폭과 깊이를 넓혀 가는 것이 효율적인 방안

- 전문가들은 클라우드보안 **위험의 주체**가 **외부적 요인(CSP 자체 취약성)**에서 ⇒
내부적 요인(사용자의 보안 전략, 통제 미흡 등)으로 전환되어 갈 것으로 분석하고 있음

Gartner

“클라우드에 안전한가요?”

No !!!

“클라우드를 안전하게 사용하고 있나요?”

문제는 클라우드 자체의 보안이 아니라, 클라우드 사용자의 보안을 위한 정책과 기술에 있습니다.

- ✓ 예측 1: 2025년까지 퍼블릭 클라우드 사용을 통제하지 못하는 조직의 90%가 중요 데이터를 부적절하게 공유할 것입니다.
- ✓ 예측 2: 2024년까지 대부분의 기업은 클라우드보안 위험 측정에 계속 어려움을 겪을 것입니다.
- ✓ 예측 3: 2025년까지 클라우드보안 실패의 99%는 고객의 잘못이 될 것입니다.

cloud security alliance®
CSA

클라우드보안 전략 및 아키텍처 부재

Rank	클라우드보안 위협 요인
1	ID, 자격증명, 액세스 및 키 관리, 권한 있는 계정 부족
2	안전하지 않은 인터페이스 및 API
3	잘못된 구성 및 부적절한 변경 제어
4	클라우드보안 아키텍처 및 전략의 부재
5	안전하지 않은 소프트웨어 개발
6	불완전한 3rd Party 리소스
7	시스템 취약성
8	클라우드 데이터 유출/노출 사고
9	서버리스 및 컨테이너 워크로드의 잘못된 구성 및 악용
10	조직적 범죄/해커/지능형 지속 공격(APT; Advanced Persistent Threat)
11	클라우드 스토리지 데이터 유출

※ 출처: Health IT Security Cloud Security Alliance
2022 주요 클라우드 컴퓨팅 보안 위협 보고서

※ Check Point

- 오래된 또 다른 클라우드보안 취약점
- . 클라우드 인프라 보안위협: 2015년 발견된 베놈(Venom) 취약점 가상머신을 탈출해 호스트뿐만 아니라 같은 시스템 상에 있는 다른 가상머신에 임의의 코드를 실행 할 수 있음.
- . 가상화 솔루션의 임의코드 실행 취약점도 2015년 발견된 바 있음.

1. 클라우드보안 개요 (5/6) – 클라우드보안 방법론

Cloud 보안 방법론은 Public/Private Cloud 보안 요소, 운영 L/C 등의 보안검토 사항을 반영해야 함.

- **Public Cloud L/C : 계약 ⇒ 이전/구현 ⇒ 운영 ⇒ 이용종료**

- Public Cloud의 경우 CSP 선정, 계약, 클라우드 인프라 대한 세부 아키텍처 / 보안성검토가 강화되어야 함.

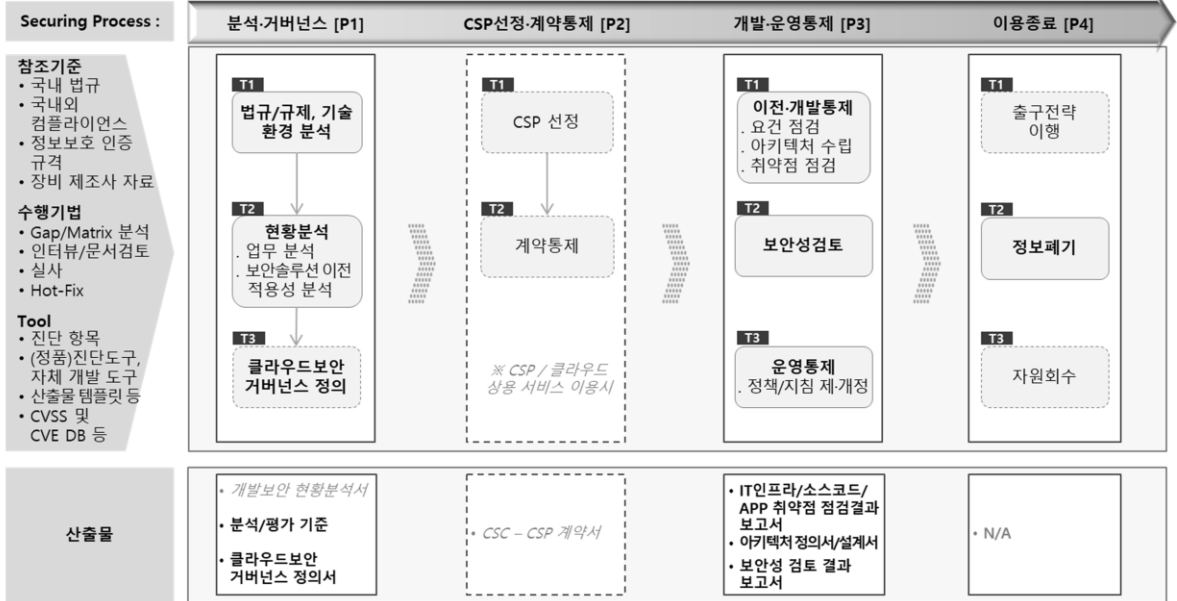
■ ICSM: INFOSEC Cloud Security Methodology

Cloud 운영 L/C 기반

Pub. Cloud 중점

법규 영역 & 실무 커버

고객사 & 컨설팅사 적용 가능



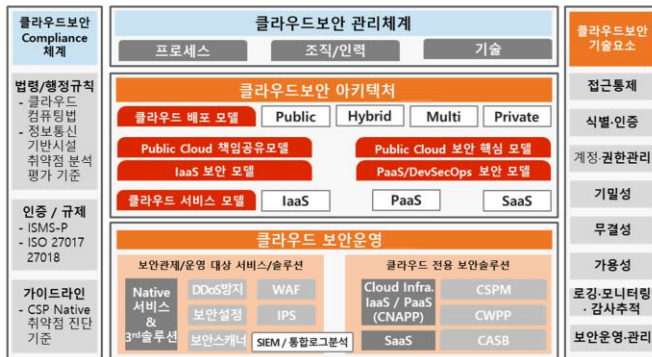
※ Check Point

- 방법론의 메인 프로세스는 진리/과학 논리에 근거한 흐름, L/C 흐름 등으로 정의하는 것이 권장됨
e.g.> input → process → output ⇒ 분석 → 평가 및 설계 → 구현 및 이행점검

1. 클라우드보안 개요 (6/6) - 클라우드보안 프레임워크의 개념적 정의

개념적·구조적 클라우드보안 프레임워크를 도식화 정의한 내용은 본문과 같습니다.

관리체계는 보통 프레임워크로 구현되고, 프레임워크는 체계 운영에 대한 점검이 가능한 체크리스트 기반으로 수립되는 경향이 있습니다. 개념적 프레임워크는 상기 체크리스트 등의 핵심사항을 개념적으로 도식화한 것 입니다.

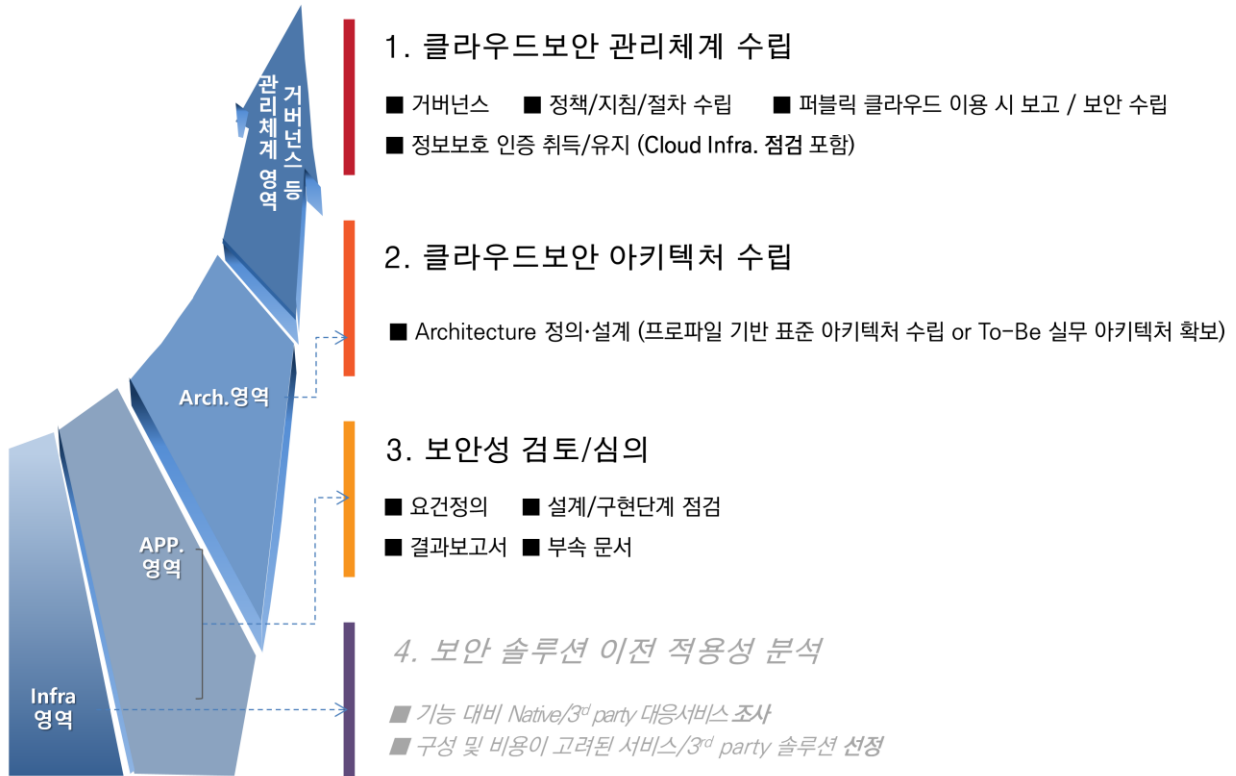


NO	영역 설명
①	클라우드보안 거버넌스와 관리체계를 수립, 점검할 수 있는 체계를 구조화함. 논리적 사고 분류 체계인 PPT(사람, 프로세스, 기술) 체계를 통하여 클라우드보안을 구조화함.
②	클라우드보안 거버넌스와 관리체계를 수립하기 위하여 회사가 준수하여야 할 법규, 지침/기준/가이드라인, 정보 보호 인증 규격을 제시함.
③	보안기술 영역에서 체계적인 접근이 필요한 접근통제 및 보안운영·관리 등 8개 영역을 정의함. 해당 보안기술요소 및 보안서비스요소를 모델화하는 것을 Cloud Security TRM이라 함.
④	클라우드 배포 모델, 서비스 모델을 고려한 클라우드보안 아키텍처 모델을 정의함.
⑤	클라우드 네이티브, 3rd party 보안 솔루션을 통한 보안운영체계를 제시함

※ Check Point

- 좋은 OO보안 프레임워크란 ?
⇒ OO에 대해서 누락없이 전체를 식별하고 보호 할 수 있는 체계

기업이 준비해야 하는 클라우드보안 사안들은 컨설팅 유형이 될 수 있음.



※ Check Point

(금융) 기업에서 준비해야 할 클라우드보안 사안은 아래 본문의 표와 같음.

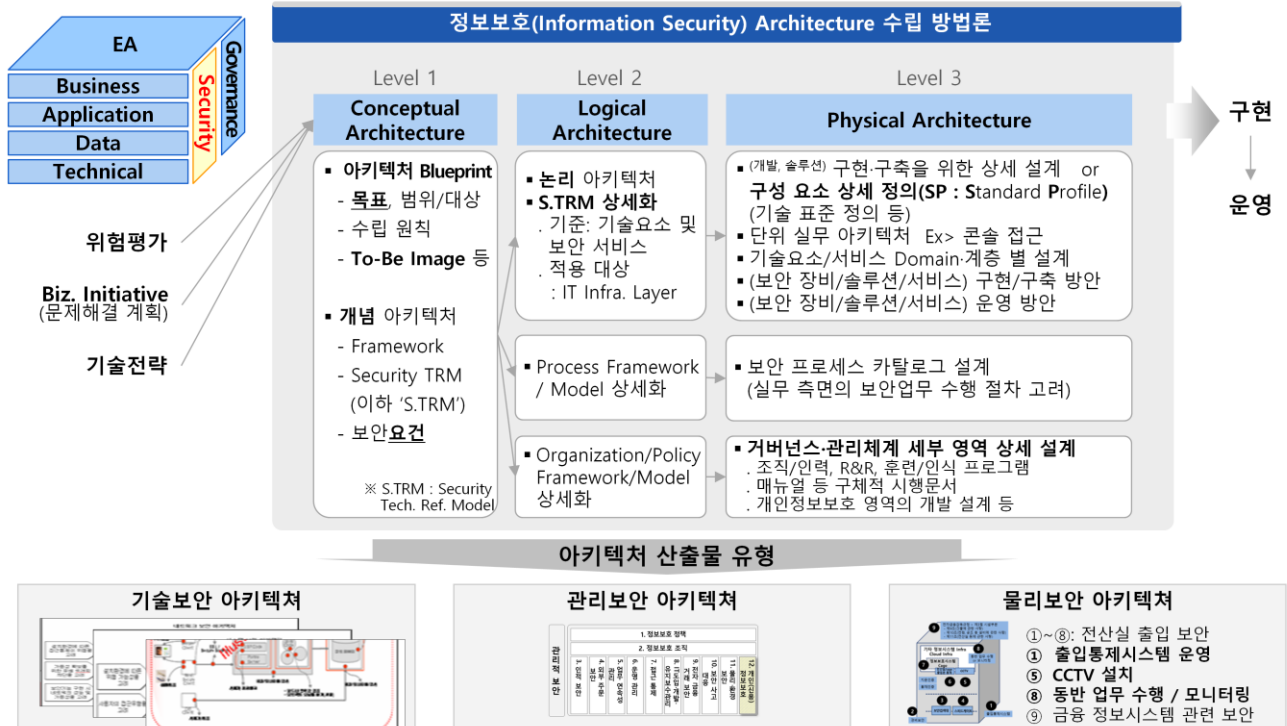
구분	준수 필요 법규	설명 / 이슈 등	비고
거버넌스 수립	-	- 적합한 인력 수급 및 유지 이슈 - 기존 인력 역량 강화와 인력 유지 이슈 - 클라우드보안 기술 체계 수립 이슈	클라우드컴퓨팅법 (CSP) 정책, 지침 제개정 과업 포함
↳ 조직/역량 강화	-	- IT 개발/운영 조직과의 클라우드 구축 견해 차이에 따른 소통에 필요한 역량 확보, 세부 기술 운영 정책 수립 이슈 - 보안 역할에 대한 R&R 이슈 - 클라우드 보안관제, 클라우드 보안운영 수행 조직 구성 - MSP 인력 활용 계획 수립 필요	클라우드컴퓨팅법 (CSP)
클라우드보안 아키텍처 정의	전자금융감독규정, 신용정보법 > 개보법, 정보통신망법 (정보보호)	- 감독규정 상의 DMZ, 중요단말 – 콘솔 접속 등 - 준수 필요 법규 상의 보안솔루션 적용 요건 - Control tower, GWLB, 세부 권한 정책 할당 등 실무 이슈	마스킹, FDS, 소스코드점검 등은 개별 규정에 근거함
클라우드컴퓨팅서비스 이용보고 (금융 – 법규)	전자금융감독규정, (금보원) 금융분야 클라우드컴퓨팅서비스 이용 가이드	- 대규모, 소규모 조직별 R&R 상이 - BCP 등 여러 조직간 협업이 필요한 문서의 품질 이슈	R&R : 정보보호 조직 + IT 개발 / 운영 조직
보안성심의	전자금융감독규정	- 개발보안과 클라우드인프라가 융합된 환경 심의 이슈 - 심의 시, 다양한 CSP 환경에 대한 노하우 필요	클라우드 적용 요건 선정 필요
정보보호 인증 관리	-	- 반드시 필요한 클라우드보안 정보보호 인증은 미존재 - 전산 자회사가 지주사에 IaaS, SaaS 제공 시 권장하는 정도	KISA CSAP - 필요시 ISMS, ISO27001 – 유지 금보원 금취분평 – 변화 적용
클라우드 인프라 취약점 점검	전자금융감독규정	- 네이티브 서비스의 자산화 기준 수립 필요 - 위험평가 기준 수립 필요	CNAPP(CSPM, CWPP)를 통한 자산 관리, 취약점 점검 대체

※ Check Point

2. 클라우드보안 아키텍처 정의 (1/5) – 보안 아키텍처 디자인 방법론(SADM) 소개

보안 아키텍처 수립 방법론

- **SADM** : Security Architecture Design Methodology
- 보안 목표/요건을 framework/model 등을 통하여 구체화 정도를 심화하여 세부 아키텍처를 수립한다.



※ Check Point

- SADM을 참조하여 Architecture Design 3원칙을 도출해 보자!
 - ⇒ 1)
 - ⇒ 2)
 - ⇒ 3)
- 일반적으로 Architecture에 적용되는 사항들
 - . Architecture 유형: Business Architecture(BA), AA, DA, TA ※ SA는 미 표준 용어
 - . Architecture 구성: **Architecture 구성요소 정의** + **TRM**(Tech. Ref. Model)
 - + 구성요소 간의 관계를 TRM을 통하여 정의 + **SP**(Standard Profile)
 - . Architecture 본체의 전개: 3레벨 전개 (모범 사례)
 - 1레벨: 추상적·개념적·비즈니스적 내용의 아키텍처 기술 (e.g. Framework, TRM 등)
 - 2레벨: 논리적인 아키텍처 레벨 기술 (e.g. TRM에 따른 모델 구성 요소별 상세 기술 등)
 - 3레벨: 구체적인 물리 영역 아키텍처 설계 내용 기술 (e.g. SP 기술, 솔루션 구축·운영 방안 기술 등)
- 아키텍처정의서에 아키텍처에 중요한 의사결정 사항들을 기록하기도 함.
- 논리: (설명안) 어떤 사물이나 대상을 프레임(구조적)으로 표현해서 공통적으로 이해할 수 있게 하는 것

2. 클라우드보안 아키텍처 정의 (2/5) – 보안 아키텍처 디자인 원칙 #1 – 개념/논리/물리 3단계 아키텍처 전개

- **Architecture:** 건축의 설계도면에 해당하므로, 누가 시공하더라도 동일한 결과물이 나올 수 있게 상세하게 잘 설계하는 것이 중요. 구성요소(개체) 정의, 구성요소간 관계와 활동, 구성요소들 간의 구조, 구성요소 상세 정의 등의 설계 원칙, 구현에 대한 지침서.
- **특징:** 개념적, 논리적인 영역은 STRM을 이용하여 architecture 정의로, 물리적 영역은 보안 솔루션 구축 설계 부문으로 정의.
- **활용:** 기술보안 architecture는 개발보안 영역에서 좀 더 중요. 개발·구축 시점이 아닌 경우 Frame, TRM 등의 상위수준으로 처리.



10

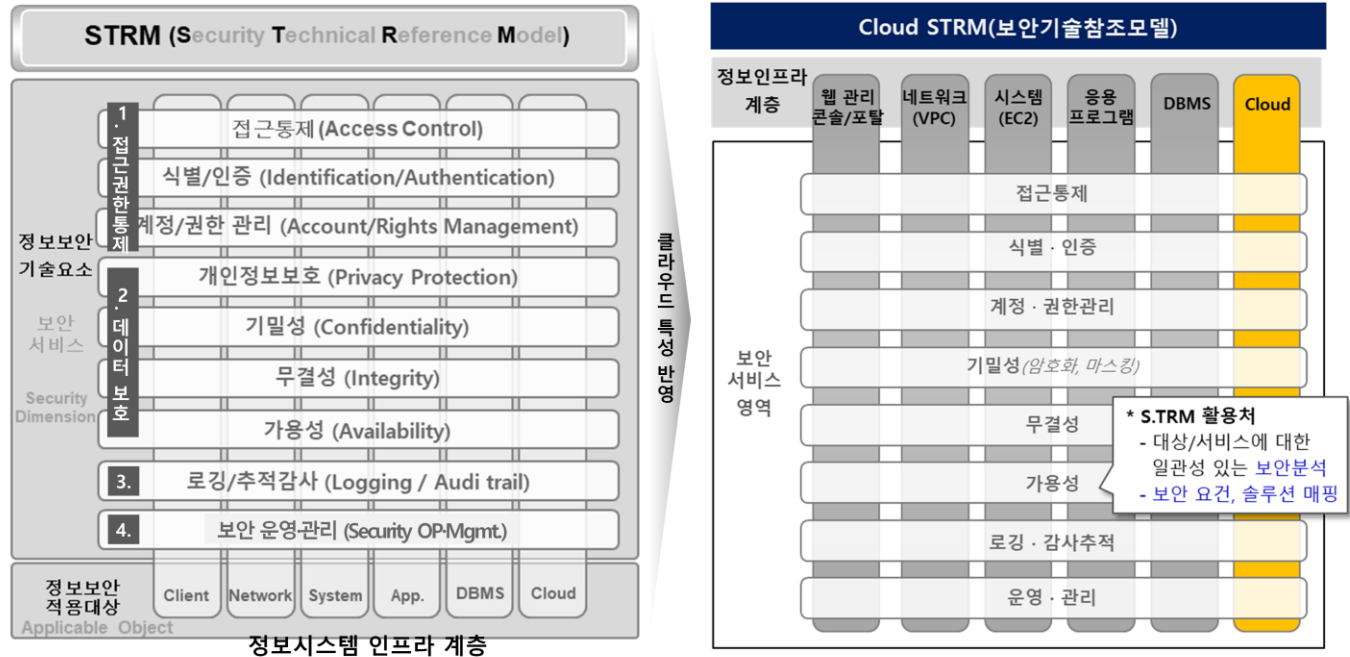
※ Check Point

- 아키텍처 '정의', '설계'로 구분하는 방식은 표준이라기 보다는 업계에서 일반적으로 사용되는 방식임.
· 작성되는 내용의 깊이(depth) 차이로 구분함.

※ de facto standard: 처음 개발/발견된 것이 널리 쓰여지는, 비 공인 상태이나 실질적인 산업 표준
대표적인 사례로 정보통신 산업계의 TCP/IP를 들 수 있음

- 아키텍처 정의서 작성 수준 및 흐름:
· 방향성 수립 > 원칙 도출 > 기준(법규근거) > 요건도출 > 아키텍처 정의 > 의결사항 도출 > 정책 수립
- 개념적, 논리적, 물리적 레벨/용어 구분은 정보시스템 개발 영역의 모델링에서 주로 쓰임
· 때에 따라서는 개념적, 논리적 구분이 모호할 경우가 존재함
- AA(Application Architecture) 측면
 - 개념적 아키텍처 : 시스템 또는 업무간 연관 관계 관점
 - 논리적 아키텍처 : 기술 구조 정의 관점 e.g. layered architecture 등
 - 물리적 아키텍처 : 구현과 배포 관점
- 필요한 선수 지식 : 시스템 분석설계 / 소프트웨어 공학

- **개요:** 많이 참조되는 국제 보안 프레임워크(e.g. ITU-T x.805 등) 등의 개념틀을 기반으로 ‘보안 기술참조모델(S.TRM)’을 정의함.
- **특징:** 정보보안 법규, 보안 프레임워크, 해킹 사고사례 등을 분석하여 MECE적인 논리 전개로 **정보보안 기술요소 영역** 선정, 정보보안 적용대상은 정보시스템 간 실제 데이터 흐름 상의 IT Infra. 구성요소(자산)로서 선정함.
- **활용:** 정보보안 프레임으로서 **개념적인 정보보안 요건 모델링, 정보보안시스템 유형 모델링 표현**에 적합함.



※ Check Point

- ITA, EA 시각
 - . 1) 용어를 혼용하여 사용하는 경우 다수 존재
 - . 2) EA 구성인 BA + AA + DA + TA 중 BA가 약화되고, IT 측면이 강화된 것을 별도로 구분하여 ITA라는 용어로 부른다는 시각
 - . 3) ITA = EA + TRM + SP 라는 시각

※ SA?, DBA?, NA? → 시스템 구현·개발 시 최적의 이해관계자 모형은? (stack building block)

- MECE: Mutually Exclusive, Collectively Exhaustive의 약자, **상호배제와 전체포괄**
 ⇒ ‘중복 없이’ < ‘누락 없이’, **보안에 있어서는 ‘누락 없이’란 개념이 훨씬 더 중요한 개념임.**
 ※ 자산이 누락되면 취약점 점검 대상 자체가 누락되어, 과업 자체를 재 수행해야 함.
- “Cloud” 이전에는 “Infra.” 또는 “물리/신기술” 영역으로 표현하기도 했음
- **Quiz : 계정은 독립적인 보안기술인가? 아니면 인증 또는 권한관리에 통합하여 표현해야 하는가?**
- 가용성에 대한 의미 고찰 필요:
 - . 가용성이란 안정성을 기준을 측정 가능하도록 계량화한 지표 (AWS 서적)
 (e.g. AP가 예상한 대로 작동하는 시간을 백분율 표시)
- ⇒ 데이터는 항상 안정되게 접근할 수 있어야 한다는 특성.
 반드시 보안과 관련된 가용성만을 다루는 협의의 의미로 적용.

AWS Native 보안 서비스, 3rd party 보안 솔루션을 보안기술요소 / 보안서비스요소 흐름으로 정의함.

AWS 예시, 수정·보완 필요

구분	웹 관리 콘솔 / 포탈	네트워크장비	서버	APP (응용프로그램)	DBMS
접근통제	CASB	CSPM Bitglass CASB and CSPM	서버접근통제 Amazon EC2 Key Pair		DB접근통제 AWS IAM (Amazon RDS(PAAS) 및 클라우드 지원)
식별인증	SSO AWS Single Sign-On		패스워드 관리 Secrets Manager	SSO AWS Single Sign-On	
권한관리 (계정관리 포함)	Bitglass CASB and CSPM, Skyhigh Networks CASB 등		계정 및 권한관리 AWS Directory Service		계정 및 권한관리 AWS Directory Service
암호화 (기밀성)		VPN Virtual Private Gateway	암호키 관리 AWS Key Management Service		DB암호화 EBS 암호화 / TDE
개인정보보호			개인정보 감시관리 IDENTITY SHIELD, Fasoos Data Rader, Endpoint Vault 등		개인정보 감시관리 IDENTITY SHIELD, Fasoos Data Rader, Endpoint Vault 등
로그/감사추적	CWPP 보안로그분석관리		McAfee Cloud Workload Security Security Hub		
가용성				백업 / 복구 AWS Backup / Snapshot 등을 통한 데이터 백업	
보안관리/침해대응/무결성		방화벽 NACL / Security Group DDoS 대응 AWS Shield APT 대응 Amazon GuardDuty IPS TrendMicro Deep Security	침입성분석 Inspector 패치관리 SSM Patch Manager 서버백신 Symantec, McAfee 등 웹사이트 및 차단 Shellmonitor, Anti-Webshell	웹방화벽 AWS WAF	
	통합보안	통합보안관리(ESM) CloudWatch / ElasticSearch Service			

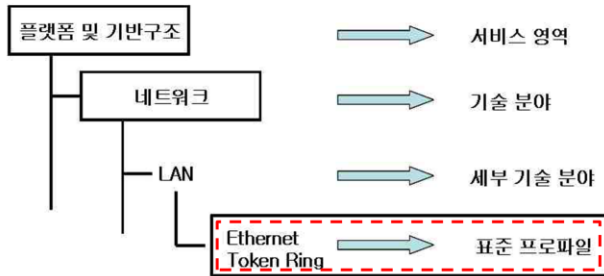
※ Check Point

- 매핑에 대한 팁
 - . 매핑이 **애매한** 보안 솔루션, 관리적 보안대책은 “보안 운영·관리 서비스” 영역으로 매핑 가능
 - 일예로 CASB는 SaaS 보호기능이 주요 기능이므로, 운영·관리-APP으로도 세부 기능 중 하나인 접근통제 기능으로도 매핑이 가능함. 다만 콘솔 측면보다는 APP 측면이 좀 더 적합함.

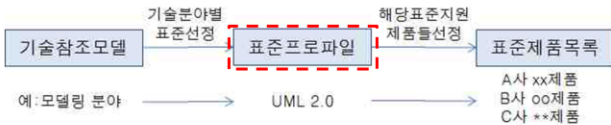
SP 정의

- IT Architecture 구성: 본체, frame을 담당하는 **RM**(Reference Model)s, 구성요소 상세를 나타내는 **SP**(Standard Profile)
- 하기 본문의 내용은 범정부 프레임워크 TRM, SP v2.3을 기준으로 서술한 것이다.

TRM 정의 단계와 SP와의 관계



TRM의 활용



‘보안 서비스’ 영역 SP 샘플

표준기술	Secure-OS		
표준번호		표준형태	기타
적용기준	선택	재개정년도	
1	표준개요 - 컴퓨터 운영 체계의 보안상 결함으로 인하여 발생 가능한 각종 해킹으로부터 시스템을 보호하기 위하여 기존의 운영 체계(OS) 내에 보안 기능이 추가된 운영 체계 - 서버의 보호, 시스템 접근 제한, 시스템 관리자에 의한 권한 남용 제한, 사용자의 권한 내 정보 접근 허용, 응용 프로그램 버그를 악용한 공격으로부터 보호 등이 요구되는 운영 체계		
개정이력	해당 사항 없음		
참고URL			

표준기술	IAM(Identity and Access Management)		
표준번호		표준형태	기타
적용기준	선택	재개정년도	
5	표준개요 - ID와 패스워드를 종합적으로 관리해 주는 역할 기반의 사용자 계정 관리 솔루션 - ID 도용이나 분실로 인한 보안 사고에 대비하여 보안 관리자에게 사용자 역할에 따른 계정 관리 - 사용자에게는 자신의 패스워드에 대한 자체 관리 기능을 제공 - 시스템과 각종 자원에 대해 고객·기업 내 사용자·관리자 등의 접근을 제어할 수 있음 - 한 번의 ID와 패스워드 입력으로 다양한 시스템에 접속할 수 있도록 SSO 또는 ID에 따라 사용 권한을 차등적으로 부여하는 EAM을 확장 또는 보완		
개정이력	해당 사항 없음		
참고URL			

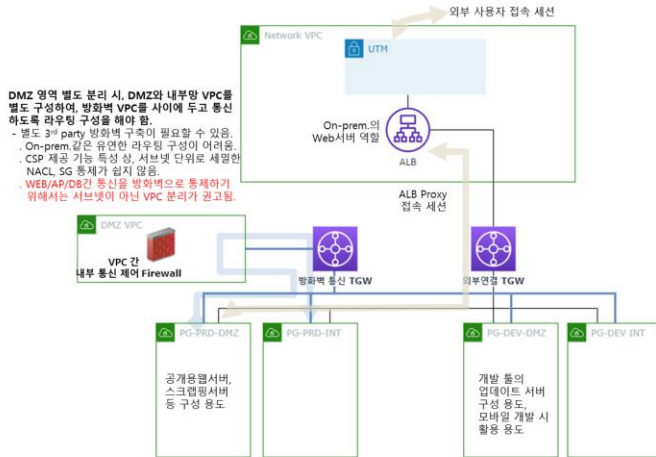
※ Check Point

- TRM 활용 목적 : 조직 정보보호 기술의 표준화
- 보안 장비/솔루션의 SP 작성 시에는 기능 Spec. 부분도 보통 작성하는 편임.

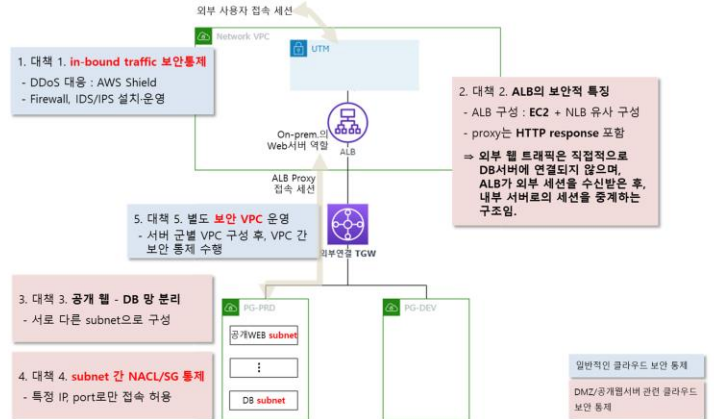
실무 포인트 아키텍처

- 아키텍처 대상 실무 포인트: 1) 계정/IAM_User 생성 및 관리, 2) 네트워크 보안 구성 / 랜딩존 구성 (2-1> DMZ, 2-2> Firewall, VPC), 3) Bastion Host 구성, 4) CSP 웹 콘솔 접근통제 방안, 5) NACL/SG 이용 접근통제 방안, 6) 서버/DBMS 접근통제 방안, 7) 암호화/키관리, 8) 로깅, 9) 머신 이미지 보호 등

명시적 DMZ VPC 구현 방안



표준 랜딩존 네트워크 구성



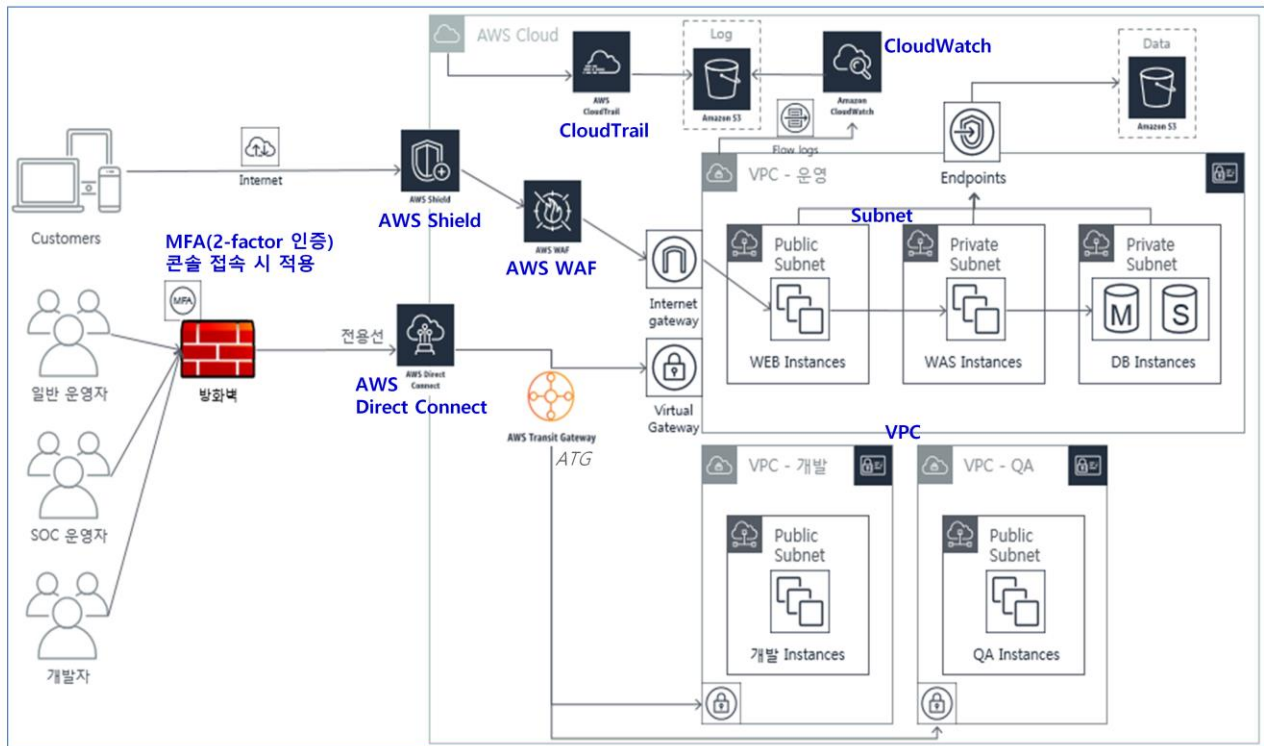
※ 주의 및 고려사항: 보안 아키텍처 구성 시, (개인)정보보호 법제 사항에 대한 준수 포인트/영역을 누락하지 않도록 해야 함.

※ Check Point

- 특정 영역별 실무 아키텍처는 S.TRM의 모든 보안기술요소/서비스를 포함하지 못하는 것이 일반적이므로 아키텍처에 대하여 법규 준수 점검을 통하여 보완하는 것이 권고됨.

Backup. AWS 기반 보안 아키텍처 수립 예시 (1/2)

- 일반적으로 시스템/네트워크 구성은 논리적 또는 물리적 영역에서 다루어 짐. (하기는 AWS 사례)
- 표현된 보안 구성 요소 : MFA, AWS Direct Connect, AWS Shield, AWS WAF VPC, subnet, AWS CloudTrail, CloudWatch

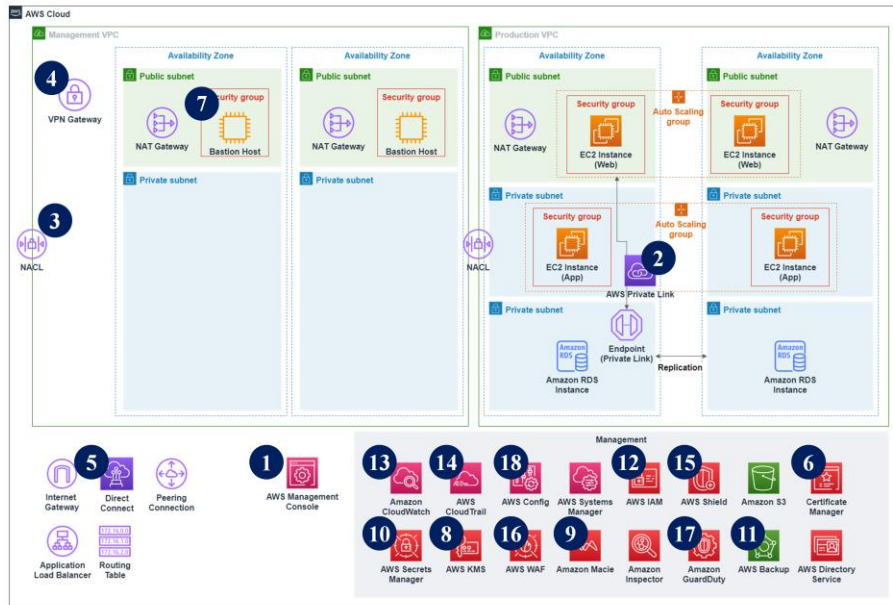


※ Check Point

- 숨겨진 보안 구성 요소 : NACL -subnet 단위-, SG(Security Group) -VM 단위-

AWS로 ISMS-P 인프라 구성 시, 다음과 같은 Native Sec. Services를 통하여 인프라를 보호할 수 있음.

■ ISMS-P 표준 보안 구성안



- 1 AWS Management Console
- 2 AWS Private Link
- 3 NACL
- 4 VPN Gateway
- 5 AWS Direct Connect
- 6 AWS Certificate Manager
- 7 Security Group, Bastion Host
- 8 AWS KMS
- 9 Amazon Macie
- 10 AWS Secrets Manager
- 11 AWS Backup
- 12 AWS IAM (MFA)
- 13 Amazon CloudWatch
- 14 AWS CloudTrail
- 15 AWS Shield
- 16 AWS WAF
- 17 Amazon GuardDuty
- 18 AWS Config

※ Check Point

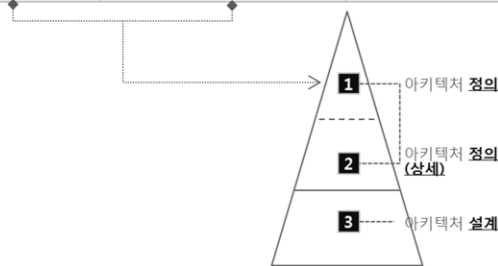
- 위 구성은 AWS 사이트에서 제공하는 ISMS-P 구성에 AWS Native Security Services를 덧대어 보완한 것임. 다만 18개 Native Security Service 외 Security Services에 대해서는 SP 형태로 별첨 등을 통하여 보완하는 것을 권고함.

Backup. 개발보안과 클라우드보안의 융합

■ 개발보안 – 클라우드보안 (점검/아키텍처) 융합의 특징

- 개발보안은 **1) 보안성 검토·심의, 2) 취약점 점검, 3) 보안 아키텍처 모듈**로 구성됨.
- 1)번: 클라우드서비스 이용 보고/보안수립, (Appl. 대상) 보안성 심의 결과 보고 등 포함
- 2)번: 클라우드 인프라 점검(필수), Native_Service/DevOps/Container 구성 SW 보안 설정 점검(선택) 수행
- 3)번: 개발자 친화적인 암호화, 계정·권한관리 영역 등의 클라우드보안 아키텍처 정의·설계

구분	분석	설계	개발	테스트
보안성검토	• 요건정의	• 설계단계 요건점검 (개발설계문서, 아키텍처 문서)	• 개발단계 요건점검 (개발 구현 화면, 로그, DB table 등)	• 결과보고서 (Open 후 7일 이내 금감원 보고)
취약점 점검	• IT/Cloud 인프라 취약점 점검 • PaaS Platform(DevOps/CI-CD 포함) 구성 요소 보안 설정 점검 (<i>강력 권고, 현재 많이 생략됨</i>)		• 소스코드 취약점 점검	• 모의해킹/Appl. 취약점 점검
아키텍처	• 영역별 아키텍처 정의 (개념적·논리적 영역)	• 솔루션 아키텍처 설계 (물리 상세 영역)	-	-



※ Check Point

- 클라우드 측면의 보안성검토·심의:
. 클라우드 전용 보안성검토 요건 등을 통하여 인프라에 대한 클라우드보안을 반영할 수 있음.

※ 주의점: 보안성검토의 중점 사항은 인프라가 아닌 APP임. 다만 APP이 탑재된 인프라 점검 결과도 보안성검토 보고서에 포함하는 것이 일반적이기에 점검하는 것 임.

3. 클라우드 기술적 취약점 분석·평가 (1/7) – Cloud Infra. vs. Native Services 점검 대상 선정 및 자산 목록화

기술적 취약점 점검 원칙: 정보자산 등재 후, 해당 대상 점검 ※ 자산 누락 절대 금지. 자산이 누락되면 보호 대상도 누락됨.

이슈: 특정 Native Service의 자산 등재 여부(예> IAM은 점검 대상이지만 자산 등재는 하지 않음),

기반시설 취약점 분석평가 유형 vs. ISMS-P 보안 인증 유형 등 컴플라이언스 유형에 따른 점검 대상화 여부

분류	서비스 명	금취 기준	Cloud Native	사유
계정	IAM	X	O	금취 각 점검 영역에 관련된 권한관리 항목으로, Cloud Native에서 점검 예정(ex. 미사용 계정, 관리자 권한 부여 등)
server	ASG(Ec2, EKS Node)	O	O	금취 기준에서 포함하지 못하는 점검 기준을 Cloud Native에서 추가로 점검
DB	RDS(Aurora, MYSQL)	O	O	금취 기준에서 포함하지 못하는 점검 기준을 Cloud Native에서 추가로 점검(암호화, 로그, 스냅샷 등)
DB	DocumentDB(MongoDB)	O	O	금취 기준에서 포함하지 못하는 점검 기준을 Cloud Native에서 추가로 점검(암호화, 로그, 스냅샷 등)
DB	elasticache	O	X	정보보호
DB	DynamoDB	O	X	정보보호
NW	Route53	X	X	정보보호
NW	CloudFront	X	O	정보보호
NW	Trangit Gateway	X	X	정보보호
NW	VPC	O	O	정보보호
NW	ELB	X	O	스토리지
정보보호	WAF	X	O	스토리지
정보보호	CloudWatch	X	X	스토리지
정보보호	CloudTrail	X	X	스토리지

미 등록 자산의 위험평가 방안

1) 자산목록 or 유사형태로 등록하는 방안
 . 취분평 : 자산 목록과 유사한 워크시트 생성
 . ISMS : App.(Cloud) 자산으로 등재

2) 위험평가는 On-prem.과 동일하게 처리
 (Native 유형을 기준으로 위험평가하는 것 보다, 호스트 대상으로 평가할 것을 강권함)

정보보호	GuardDuty	X	X	개별 Native 서비스 및 네트워크 인프라 점검에 활성화 여부를 점검
정보보호	SG	O	X	금취 항목 중 방화벽 정책에 관련된 항목을 기준으로 점검 예정
정보보호	NACL	O	X	금취 항목 중 방화벽 정책에 관련된 항목을 기준으로 점검 예정
정보보호	KMS	X	O	키관리 서비스 접근 권한 및 개별 Native 서비스에 암호화 관련 여부를 점검함
스토리지	S3	X	O	S3 버킷, 파일의 public access 여부 등 점검
스토리지	EBS	X	O	public access, 암호화 등 점검
스토리지	ECR	X	X	금취 기준에 부합하는 보안 요건이 존재하지 않음
스토리지	EFS	X	O	EFS 에 저장된 파일에 암호화, 백업 등 점검
서버리스 컴퓨팅	Lambda	X	X	Imbda를 이용한 네트워크 인프라 구성은 점검하나, lambda 서비스는 점검할 요건이 없음
k8s	EKS	X	X	EKS 노드는 금취 기준으로 점검이 가능하나, EKS 서비스의 점검 할 보안 요건은 없음
k8s	ECS	△	△	TBD
etc	MSK	X	X	점검할 보안 요건이 존재하지 않음
etc	MWAA	X	X	점검할 보안 요건이 존재하지 않음

※ Check Point

- 클라우드 인스턴스 유형(EC2, RDS 등)은 서버 자산 목록에 등록하여 점검 및 위험평가 수행함.
- 참고적으로 클라우드 인프라에 대한 위험평가는 On-prem. 인프라 위험평가 체계와는 맞지 않는 점이 많기에 누락되는 경우가 많음. 단 ISMS-P 등의 인증 수검 시에는 위험평가 내역이 필수적임.
 - . VPC, Subnet, NACL/SG 등 네트워크 구분, 보안기능은 **자산화 하지 않지만** 점검 해야 하는 경우
 - . 점검 단위를 나눌 때 Host 단위가 아닌 **계정 단위** 내 소속 인스턴스나 리소스 기준으로 점검 해야 하는 경우
 - . 위험평가 시에도 취약한 Host 단위가 아닌 **점검 항목 기준으로** 평가가 많이 일어나 설득이 쉽지 않다는 점

3. 클라우드 기술적 취약점 분석·평가 (2/7) – Cloud Native Services 점검 대상 선정 및 자산 목록화

ISMS-P 자산관리대장 내 클라우드 Native Services를 등록하는 예시는 본문과 같음.

6. 응용프로그램(Cloud) - Cloud Native Services

수량

12

No.	기본정보				책임자	
	계정이름	계정번호	Cloud Native Services (자산 평가 대상)	HostName	부서	성명
1	lottemartgo	044432258136	VPC	dev vpc - (vpc-0bad95761b6fe43b1) prod-vpc admin aszx1525@lottemart.com bottlebunker s3 access CDS_S3_PROD CDS_S3_TEST l.jeyoung.kim@lotte.net CMS_S3_PROD CMS_S3_TFST dhkim@pentaworks.vyz dhkim239@lotte.net	원두원시스템개발팀	권기실
2	lottemartgo	044432250136	IAM		운영자	
					부서	성명
					C	I
					A	보안등급
					원두원시스템개발팀	권기실
					3	3
					3	3
					3	상

※ Check Point

3. 클라우드 기술적 취약점 분석·평가 (3/7) – On-prem. 대비 Cloud Infra. 취약점 점검의 특이점

클라우드에는 **Container** 등의 다양한 Application 현대화 기술을 적용하므로 **점검 방식도 다양**해 질 수 있음.
 특히, Container 취약점 점검은 **Container 수렴 전 점검을 원칙**으로 하나, 이미 수렴된 Container 보안을 위해서는 **CSPM** 등의 전용 SW를 통한 취약점 점검이 필요함.

구분			AWS (Public) 점검 방안	
보안장비 (설치 형, Container 형)			* 인터뷰 / 실사 통한 수동점검 (On-prem.과 동일 방식)	
WEB/WAS	VM 내 설치 유형		* 알려진 WEB/WAS 점검 기준에 따른 분석평가 수행	
	Container	Container 수렴 전 구성 요소 점검	* Config.파일 점검, 인터뷰/실사 통한 수동점검 * 패치, 설정 변경은 Container 수렴 전 수행하는 경우가 많음.	
		Docker 생성 Container의 경우	* Docker 명령어 이용 스크립트써 점검 수행 가능 * 개발 역량이 필요하며, 버전 및 설치위치에 따른 유지보수 비용 과다하게 소모됨. (전문 점검팀에서도 유지가 쉽지 않음)	
		Docker 외 생성 Container의 경우	* 점검 기준에 대한 인터뷰/실사 통한 수동점검	
		전용 SW로 취약점 점검	* 3rd party	
DBMS	VM 내 설치 유형		* 기반사	
	Container	원격에서 SQL로 보안설정 점검	* 원격 스캔	
		접속 톨 admin 계정 접속, 실사	* 인터뷰	
		Docker 생성 Container의 경우	* Docker * WEB/WAS	
		Docker 외 생성 Container의 경우	* 점검 기	
VM (OS) (Infra. 서비스)	EC2 / AMI	LINUX / MAC OS / Windows	* 점검 기 * 커스터마이징 및 결과 (차이점)	
가상화 장비. Network 장비			* CSPM	

Container - Kubernetes

Kubernetes - Container

Container - Kubernetes == Kubernetes - Container

(Base Container -WAS만-)

(Completed Container -add on APP-)

PaaS on Cloud(Infra 제공)

On-premise(AP 개발)

①

②

- PaaS(RHOCN)에서 WAS만 포함된 base container 생성

- ① 생성된 컨테이너를 on-premise Kubernetes로 전달하여, 개발된 APP을 Container에 포함시킴

- ② 온전한 Container를 PaaS에 전달하여 Container를 배포/실행 수행

자산 분석·평가

■ 고려사항 : 자산 분석의 시기는 현황분석 또는 위험평가 단계에서 수행할 수 있음. 이는 자원 허용 상황에 따라 PM이 결정 권고함.

자산 분석 절차 및 방안

자산식별

- 정보시스템 운영 담당자, 시설 담당자, 보안장치 운영 담당자 등 전산자원 관리자를 통한 자산목록 수집 및 자산 식별

자산분류 및 그룹핑

- 자산유형 정의
- 정의된 유형에 따라 수집된 자산목록 정리
- 전산자원의 특성에 따른 자산 그룹핑

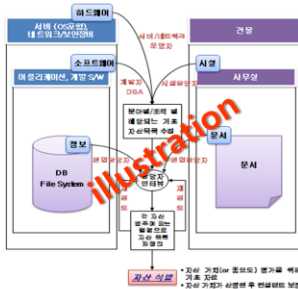
자산 중요도 평가

- 자산 평가 기준 정의
- 전산자원 유형 및 그룹을 바탕으로 중요도 평가
- 자산 분석서 작성

전산자원 보안등급 부여

- 자산 중요도 평가에 따른 정보 자산의 보안 등급 정의
- 자산 중요도 평가 및 정의된 보안 등급을 바탕으로 전산자원 보안 등급 부여

자산식별 절차



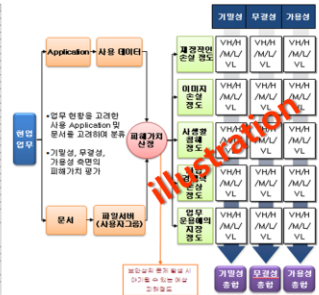
자산분류

자산 식별	자산 분류	자산 번호
Physical Asset	Computer & Communication Equipment	정보
Information Asset	Database & Files	문서
Document Asset	Contract Document	하드웨어
Software Asset	System Software	소프트웨어
People Asset	Personnel	시정
Image & Reputation	Image & Reputation	
Service Asset	Network Services	

자산 그룹핑

그룹핑 기준	그룹핑 결과
• 동일한 기능이나 유사한 업무에 사용되고 있는 자산의 경우 (ex. DB서버, 복원서버 등)	정보
• 자산에 종속된 자원은 가능한 한 수행하기 어려우며 다른 자산과 복합적으로 기능을 수행하는 경우 (ex. WEB 서버, WMS 등)	문서
• 동일한 관리자를 통해 관리되고 있는 경우 (ex. Unix, Windows, MW 등)	하드웨어
• 유사한 위험 및 취약점을 갖는 자산의 경우 (ex. Unix, Windows, Oracle, Sybase 등)	소프트웨어
	시정

자산 중요도 평가



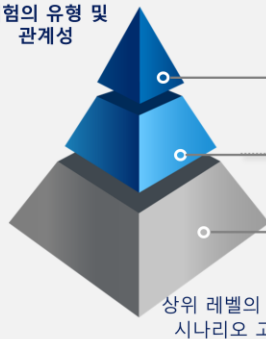
※ Check Point

위험 분석·평가

■ 실무 조언 : 다양한 방식의 위험도 산정, 위험 조치 시기 산정 등은 **취약 사항 대상으로 엑셀 수식을 사용하여 수행한다.**

위험분석 및 위험도 산정

위험의 유형 및 관계성



단위 시스템 별 위험
정보 자산 그룹에 대한
직접적인 위험요소 규명

접근 경로 별 위험
논리적/물리적 접근 경로에
따른 유출/변조/장애에 대한
위험요소 규명

공통관리 위험
전체 정보자산에 공통적으로
영향을 미칠 수 있는 관리적
위험요소 규명

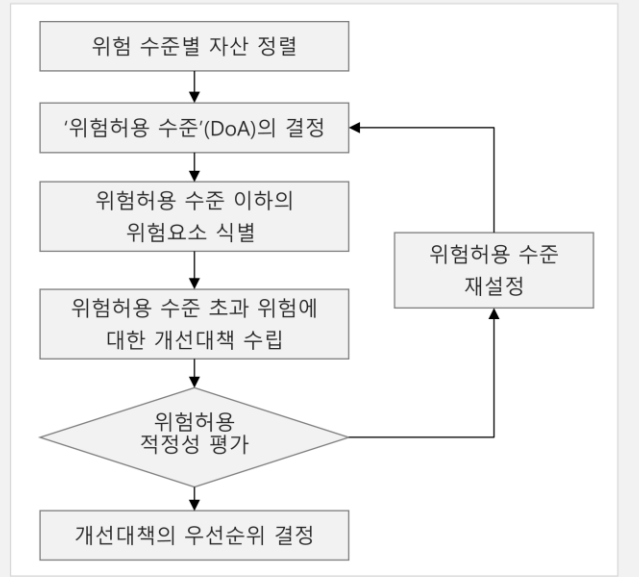
상위 레벨의 위험
시나리오 고려

■ 위험 시나리오를 기반으로 실제 침해 발생 가능성, 피해 정도 등을 고려

위험 시나리오(예시)	위험도
계정 패스워드에 대한 자릿수 제한에 제한이 없어 패스워드 크래킹의 위험이 높음	High
Backbone망과 연결 되어 있는 관계사를 통한 우회침입에 의해 개인정보의 유출 및 변조 가능	High
외부업체직원의 반입장비를 통한 중요정보 접근 열람 가능	High

DoA 기반 위험관리 절차 및 방안

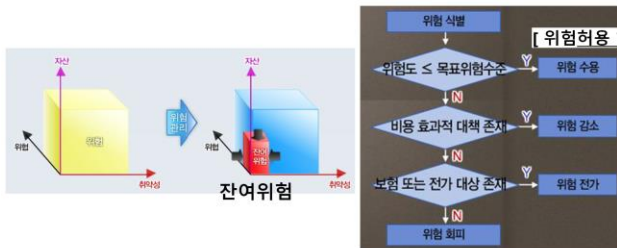
- DoA(Degree of Assurance)는 자산 중요도, 위협 발생 가능성, 위험 영향도 등을 고려하여 위험도 산정



※ Check Point

위험관리

- **위험 관리 [risk management, 危險管理]** : 정보 시스템 자산에 피해를 끼칠 수 있는 위협의 영향을 확인, 통제, 제거, 최소화하는 전체 과정. 위험 분석 및 평가, 위협의 처리에 대한 결정, 보호 대책의 선정 및 구현, 잔여 위험 분석 등을 포함하는 순환적 과정으로 이루어진다. [참조: 네이버 지식백과, IT용어사전/한국정보통신기술협회]
- 위험 분석 및 평가 = 식별된 자산 중요도 평가 + 자산 외부 위험 평가 + 자산 내부 취약점 평가(웹진단+정보시스템진단)
- 위험평가는 분석 대비, 위험도 등 수치 점수화를 통한 정량화 뿐만 아니라 보호 대책의 선정까지도 일반적으로 포함한다.



NO.	위험관리	설명
0	위험관리 목표	- 위험을 한계위험 이하로 낮추어 관리 (위험완화) - 잔여위험(residual risk)을 허용 가능한 수준으로 유지
1	위험감소 = 위험처리	- 취약점/위험 감소 활동을 통한 위험감소 관리 - E.g. 정보시스템 취약점 조치
2	위험회피	- E.g. 위험이 존재하는 사업 또는 일부 서비스 영역 포기
3	위험전가	- 보험 등으로 위험에 대한 책임을 전가(전이)함
4	위험수용 = 위험수용 = 위험감수	- 위험을 받아들이고 비용을 감수함 - 비용편익 분석 상, 보호대상 자산의 가치보다 보호대책 구현 비용이 높을 때 (대책 비용 > 위험감소 구현 비용), 또는 보호대책 구현이 현실적으로 불가능할 때, 이를 위험수용 항목으로 선정하고 CISO 등에게 승인관리 수행

※ 위험관리 상의 위험수용과 DoA 이하 위험에 대한 허용가능 위험에 대한 용어 혼용 고려사항.

위험수용 항목은 관리 대상 항목으로 위험평가 보고서 등에 반드시 명기되어야 함.

또한 위험수용을 보안 취약점 평가 시, 수검사 환경을 고려한 평가항목 양호 처리를 위한 예외 승인 관리 활동과 오해하여서는 안됨. 양호 항목으로 관리되는 평가항목은 위험이 될 수 없고, 보고서에도 양호로 관리되어야 하기 때문임.

위험 분석·평가 관리 기본

구분	설명	비고
위험 분석·평가 관리 개념 소개	용어	- 위험 vs 이슈·문제점. (위험: 부정적인 일이 발생할 수 있는 가능성) - 잔여위험, 한계위험, DoA, 비용편익분석 , 식별/수용·허용·감수/감소·처리/전가·전이/회피
	위험의 구성요소들과 관계성	- 위험 --(공격)--> 취약성 --(노출)--> 자산 --(보유)--> 가치 --(보호수단)--> 보안요구사항 --(충족)--> 보안대책 --(방어대상)--> 위험 == (관리) => 위험
위험 분석·평가 (Analysis-Assessment)	정의	- 위험을 조사, 식별하여 해석, 평가하는 과정 (단, 실무적으로는 보호대책 포함. 조치대책 분리 권고) . 수집, 조사, 식별, 분석, 평가 단계의 순차 수행 (실무적으로는 취약점 한정으로 상세분석 수행)
	위험 분석 및 접근 방법론	- 위험분석 방법론(정량, 정성), 위험분석 접근법(기준선 접근법, 전문가 판단법, 상세위험 분석법 등) - 회사의 취약점 평가는 ' 복합적 접근법(Combined Approach) '을 적용함. 기술적 취약점 평가에서는 ' 상세위험 분석법(Detailed Risk Analysis) '을, 그 외적으로는 기준선 접근법 을 적용함.
	위험 산출식 대표적 예시	- 구 KISA : C.I.A. 기반, 자산(Asset) + 취약점(Vulnerability) + 위협(Threat) - 보호대책(Safeguard) 물(자산) + 내 몸의 컨디션(주로 내부 취약성) + 감기 바이러스(주로 외부 위협) (C + I + A) * 법규충족도 (법규 해당 2, 아니면 1), 항목 중요도·우려도 * Y/P/N 취약도 - PIA : 위험도 = 자산가치(영향도) + (침해요인 발생 가능성 x 법적 준거성) x 2
위험관리 (Risk Management)	정의 및 목적	- 정의 : 위험을 인식하고, 적절한 비용 이내에서 필요한 통제 방안을 선택함으로써 위험과 취약성을 적절히 통제하는 과정 - 목적 : 위험을 수용 가능한 수준으로 감소시키는 것. 즉 한계위험 이하로 위험감소 시키는 것.
	절차	- 위험관리 계획 수립 → 위험 식별 → 정량/정성 위험분석 수행 → 위험 대응 계획 수립 → 위험 감시·통제
	전략	- 위험관리 전략 (광의) ≡ 위험통제 방안 (협의)
기타	위험관리 이슈 등	- 적용 우선 순위 : 1) 고객사 위험관리 정책, 2) 공개된 표준案 (PIA 등), 3) 컨설턴트 수행案 - 평가 배점의 주관성 개입 범위 : 평가 배점 범위가 커질수록(예, 3 → 5점) 개입 범위가 더 커지게 됨. - 분석, 평가 각 단계에서 분석과 평가 행위가 공존하게 됨. 두 단계를 분리하면 논리적 오류 발생.

※ Check Point

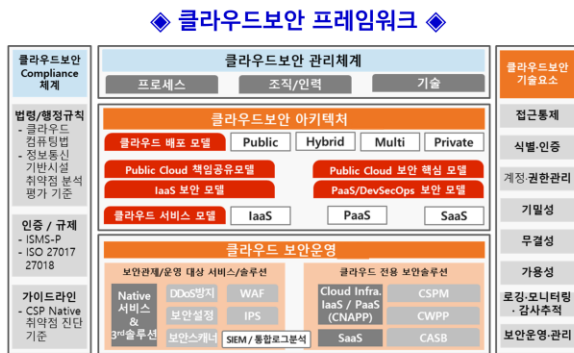
- 학습 필요 내용:
 - 1) 용어 및 기본 이론
 - 2) 절차 : 본문 참조
 - 3) (엑셀결과서/워드보고서) 양식 활용법 : 법규 또는 인증 규격이 요구하는 정보 고려
 - 4) 수행 고려사항 및 이슈 : 기준 및 설정 값의 개인적 주관의 개입 범위 등

4. 클라우드보안 마스터플랜 수립 (1/7) - 프레임워크 대비 개선사항 도출 #1

클라우드보안 프레임워크 대비 현행 수준을 대조하여 핵심 주요 개선사항을 제시함.

본문의 예시는 모 사이트의 클라우드 보안 프레임워크 대비 주요 개선사항 예시 임.

본래의 마스터플랜 수립은 클라우드보안 관리체계 평가항목 기반으로 개선사항을 도출하는 것이 일반적 임.



타사 사례 : 1년차 2년차 3년차

범례	△	◎	◐	●	★
설명	초기	성숙기#1	성숙기#2	안정기#1	안정기#2

영역	명칭	현수준	주요 개선사항 요약
①	프로세스	◎	※ Compliance체계 영역 포함
	조직/인력	△	- 전담인력 미확보 (외주 포함) - 유관 교육 로드맵 미 수립
	기술	◎	※ ③~⑤번 기술영역으로 대체
②	클라우드보안 Compliance 체계	◎	- Cloud 특화 점검 영역 미흡 (관리 영역 체크리스트 미흡) (※ 롯데마트의 정보보호 체계는 KISA ISMS 기반이므로 '양호' 수준이라 판단할 수 있음. 지침 작성 등) - R&R 미흡 : 보안솔루션 운영 등
③	클라우드 보안 기술요소	◎	클라우드 취약점 진단 체계 고도화 필요 (진단 툴 도입, 소스코드 / 개발 툴 / PaaS / 보안설정 진단 등)
④	클라우드 보안 아키텍처	△	- 표준/실무 클라우드보안 아키텍처 수립 필요 (CSP별 수립 필요) 클라우드 로그 검토 수행 미흡
⑤	클라우드 보안운영	△	서비스/솔루션 도입 미흡 (운영 등의 R&R 정리 선행 필요)

※ Check Point

- 프레임워크(Framework)의 용어 정의
 - . 뼈대, 골조(骨組), 프레임워크(framework)
 - . 컴퓨터 프로그래밍 소프트웨어 프레임워크(software framework): 복잡한 문제를 해결하거나 서술하는 데 사용되는 **기본 개념 구조**

※ 참고 용어: net(그물) vs network(통신망, 인맥, ... 등으로 확장)

- . Work 용어의 Nickname: job이 아닌 사무실, 즉 일하는 공간, 체계 등의 의미를 포함함.
- . Frame(창틀, 뼈대, 골조 등) → **framework(뼈대를 움직이게 하는 체계 정도로 확장)**

프레임워크 “①클라우드보안 관리체계” 영역 대비 현행 수준을 대조하여 개선사항을 도출하였음.

NO	영역	분야	항목	평가	현황 및 문제점	개선안
①	클라우드보안 관리체계	P (프로세스)	1.1.1 정보보호 전략	양호	▪ On-prem. 영역에 포함 처리	▪ -
			1.1.2 정책 및 프로세스 수립	양호	▪ 클라우드 운영 보안 지침 운영	▪ -
			1.1.3 조직 및 인원 R&R 정의	미흡	▪ 클라우드 보안운영 R&R 미 정립	▪ 클라우드 보안 솔루션 도입 전 R&R 사전 정립
			1.1.4 컴플라이언스 프레임워크	미흡	▪ 클라우드보안 프레임워크 수립 ▪ 클라우드 특화 점검 영역 미흡	▪ - ▪ ISMS 항목 외 클라우드보안 전문 체크리스트 보완
		P (조직/인력)	1.2.1 정보보호 조직/인원 구성	취약	▪ 유관 전담인력 미확보 (On-prem. 영역 포함)	▪ 전담인력 또는 외주조직에 클라우드 보안인력 확보
			1.2.2 전문 역량 확보	취약	▪ 유관 교육 로드맵 미 수립	▪ 자격 교육, 전문 교육 로드맵 수립
			1.2.3 성과 측정 및 평가	양호	▪ 클라우드보안 관련 KPI 존재	▪ -
			1.2.4 커뮤니케이션 체계	미흡	▪ CISO 대내 활동 강화 권고 (On-prem. 영역 포함)	▪ CISO 캐릭터 제작, 위규자들과 전부서 투어 홍보 등
		T (기술)	1.3.1 클라우드 보안기술요소	N/A	▪ N/A	※ 아키텍처, 운영 항목에서 취급
			1.3.2 클라우드보안 아키텍처	미흡	▪ 표준/실무 아키텍처 미 수립 ▪ 취약점 진단 체계 고도화 필요	※ ④번 영역에서 상술
			1.3.3 클라우드 보안운영	미흡	▪ 일부 보안설정 미흡 ▪ 서비스/솔루션 도입 미흡	※ ⑤번 영역에서 상술

※ Check Point

4. 클라우드보안 마스터플랜 수립 (3/7) – 프레임워크 대비 개선사항 도출 #3

정의된 프레임워크 대비 현행 수준을 대조하여 개선사항을 도출합니다.

NO	영역	분야	항목	평가	현황 및 문제점	개선안
②	클라우드보안 Compliance 체계	법령/행정규칙	2.1.1 법령/행정규칙 정책화	양호	▪ 법규 반영 규정, 지침 운영	▪ -
		인증 / 규제	2.2.1 인증 / 규제 준수	양호	▪ KISA ISMS 인증 유지 ▪ 매년 그룹 보안진단 수검	▪ -
		가이드라인	2.3.1 기술 가이드라인 수립	미흡	▪ Native 기술 진단 체크리스트 수립 ▪ 매월 검토 대상 로그 미정의	▪ - ▪ AWS Cloudtrail 검토 대상 로그 정의 (가이드 작성)
③	클라우드 보안기술요소	-	-	-	▪ N/A	※ 보안 아키텍처, 보안운영 항목에 포함하여 취급함
④	클라우드보안 아키텍처	클라우드보안 아키텍처	4.1.1 보안기술요소를 포함한 클라우 드보안 아키텍처 수립	미흡	▪ 표준/실무 아키텍처 미 수립 ▪ 취약점 진단 체계 고도화 필요	▪ 표준/실무 아키텍처 수립 (CSP별 아키텍처 수립) ▪ 취약점 진단 체계 고도화 (진단 툴 도입, 소스코드 / 개발 툴 / PaaS / 보안설정 진단 방안 체계 수립)
⑤	클라우드 보안운영	클라우드 보안 운영	5.1.1 클라우드 보안운영	미흡	▪ 일부 보안설정 미흡 ▪ 서비스/솔루션 도입 미흡	▪ ISMS 결함, 취약, 지적 사항 포함하여 조치 ▪ CNAPP 도입

※ Check Point

4. 클라우드보안 마스터플랜 수립 (4/7) – 프레임워크 대비 개선사항 과제 정의 #1

도출된 개선사항을 과제로 정의하고 구현 권고기간을 제안함.

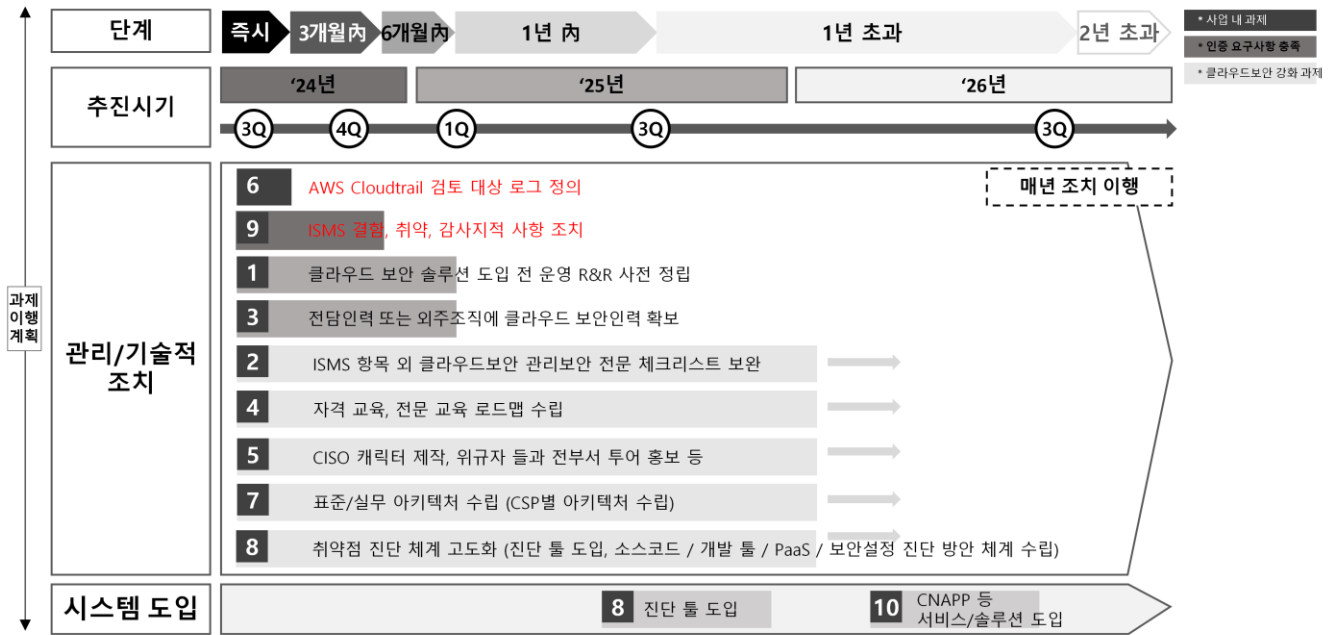
구분	추진과제	세부과제	중요도	긴급성	적용성	효과성	합계	권고기간
1	클라우드보안 관리체계 개선	1 클라우드 보안 솔루션 도입 전 운영 R&R 사전 정립	2	3	1	2	8	6개월 내
		2 ISMS 항목 외 클라우드보안 관리보안 전문 체크리스트 보완	1	1	3	2	7	1년 초과
		3 전담인력 또는 외주조직에 클라우드 보안인력 확보	3	2	1	2	8	6개월 내
		4 자격 교육, 전문 교육 로드맵 수립	1	1	3	1	6	1년 초과
		5 CISO 캐릭터 제작, 위규자들과 전부서 투어 홍보 등	1	1	3	2	12	1년 초과
2	클라우드보안 Compliance 체계 고도화	6 AWS Cloudtrail 검토 대상 로그 정의 (가이드 작성, 금번 사업 내 과업 수행)	3	3	3	3	12	즉시
3	클라우드보안 아키텍처 수립	7 표준/실무 아키텍처 수립 (CSP별 아키텍처 수립)	2	1	2	2	7	1년 초과
		8 취약점 진단 체계 고도화 (진단 툴 도입, 소스코드 / 개발 툴 / PaaS / 보안설정 진단 방안 체계 수립)	3	-	1	3	7	1년 초과
4	클라우드 보안운영 개선	9 ISMS 결함, 취약, 감사지적 사항 조치	2	3	2	3	10	3개월 내
		10 CNAPP 등 서비스/솔루션 도입	2	2	2	2	-	26년 1H

구분	즉시	3개월內	6개월內	1년초과	2년초과
점수	12, 11	10, 9	8	7, 6	5~0

※ Check Point

4. 클라우드보안 마스터플랜 수립 (5/7) - 프레임워크 대비 개선사항 과제 정의 #2

정의된 과제의 일정계획과 과제 유형에 대한 추가 정보를 제공함.



※ Check Point

4. 클라우드보안 마스터플랜 수립 (6/7) - 개선사항 과제 카드 정의 #1 - 클라우드 보안 조직 구성

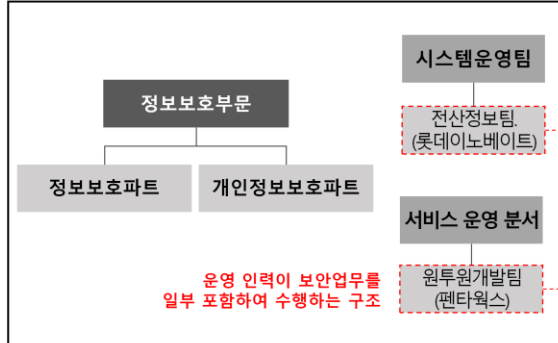
추진과제	이행형태	우선순위	필요자원	관련부서
0.1 전담 외주 보안 운영 조직 신설	내부 이행	1년 초과	외부	시스템운영팀

- 보안 - 운영의 직무 분리 필요, 보안 인력에 대한 업무 지배력 강화 필요
- 클라우드보안 전문가 필요

□ 현행 정보보호 조직의 이슈

- 정보보호 업무 지배력 낮음: 사유 - 보안/운영의 직무분리 위배, 잦은 동일 취약점 재발, 운영 인력 일정에 의한 정보보호 업무 일정의 잦은 변화, 보안인증 대응용 보안활동/설정의 배제 등

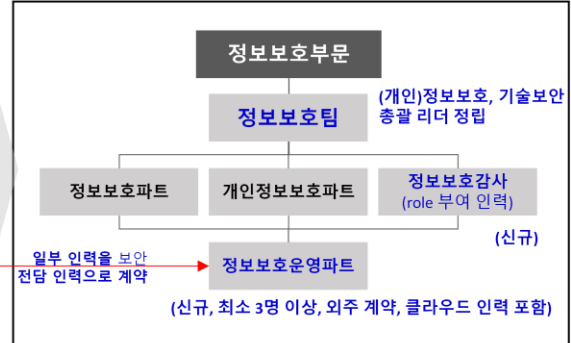
【 현행 정보보호 조직 현황 】



□ 정보보호 조직력 강화 방안

- 정보보호 조직의 양적 성장: 팀제 조직화, 보안감사 를 활성화, 외주 계약을 통한 정보보호운영파트 신설
- 정보보호 조직의 질적 성장: **보안 업무 지배력 강화**

【 권고 정보보호 조직 구성(안) 】



2025년	추진일정												소요비용	
	1	2	3	4	5	6	7	8	9	10	11	12	인력	H/W & S/W
													인당 월 6백 * 3명	-

4. 클라우드보안 마스터플랜 수립 (7/7) - 개선사항 과제 카드 정의 #2 - CNAPP 도입.구축

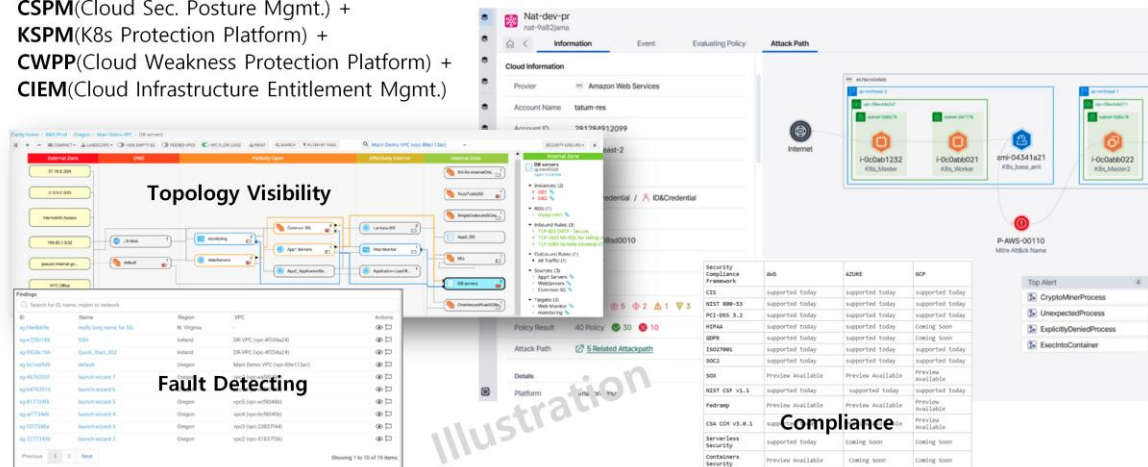
추진과제	이행형태	우선순위	필요자원	관련부서
0.1 CNAPP(Cloud Native App. Protection Platform) 도입	시스템 구축	26년 1H	외부/내부	정보보호부문

- 클라우드보안 형상관리(CSPM), 클라우드 악점 보호 플랫폼(CWPP) 등의 솔루션 장점을 통합한 CNAPP 도입
- 클라우드 자산 가시성, 컨테이너 점검 등

□ CNAPP 시스템의 구성 요소 및 주요 기능

CSPM(Cloud Sec. Posture Mgmt.) +
KSPM(K8s Protection Platform) +
CWPP(Cloud Weakness Protection Platform) +
CIEM(Cloud Infrastructure Entitlement Mgmt.)

< TATUM CNAPP's Demo >

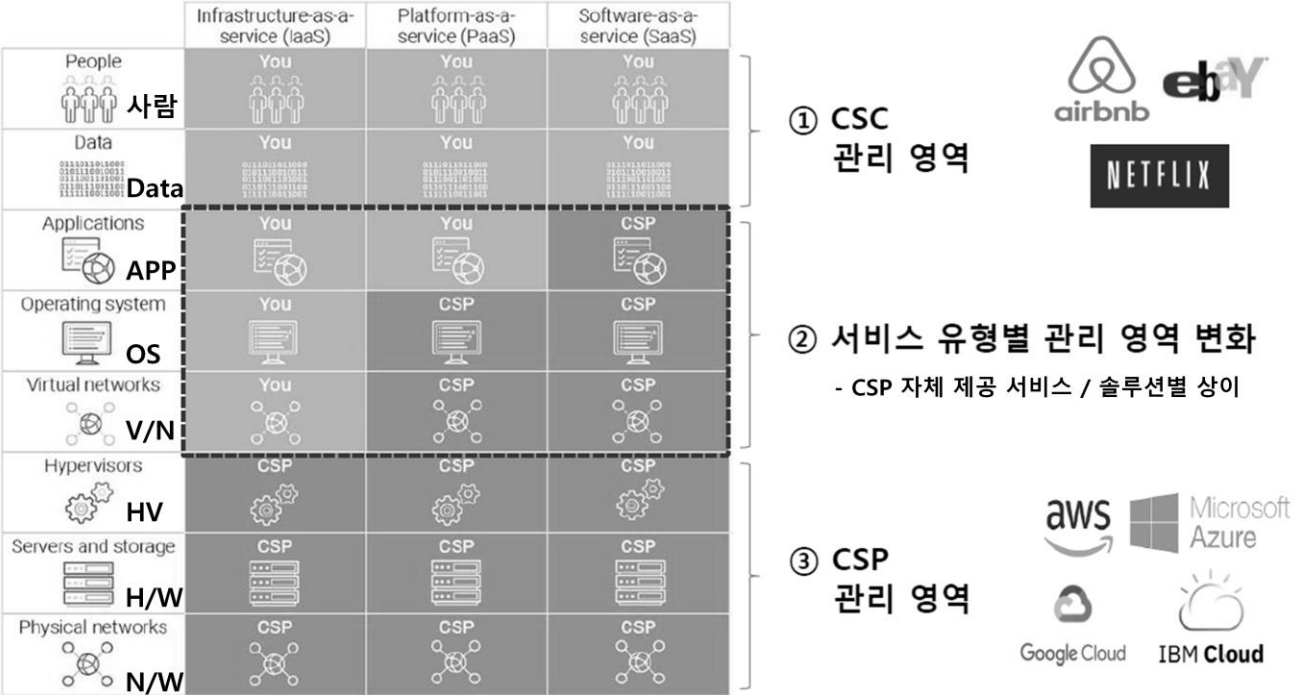


2026년	추진일정												소요비용	
	1	2	3	4	5	6	7	8	9	10	11	12	인력	H/W & S/W
	6.1 (26년 1H)												-	-

End of Documents

[별첨.1] 책임공유모델(Shared Responsibility Model) (1/3)

Cloud 보안 위험을 대응하기 위해서는 고객, 서비스 제공자가 **책임져야 할 각자의 영역을 이해**해야 함.

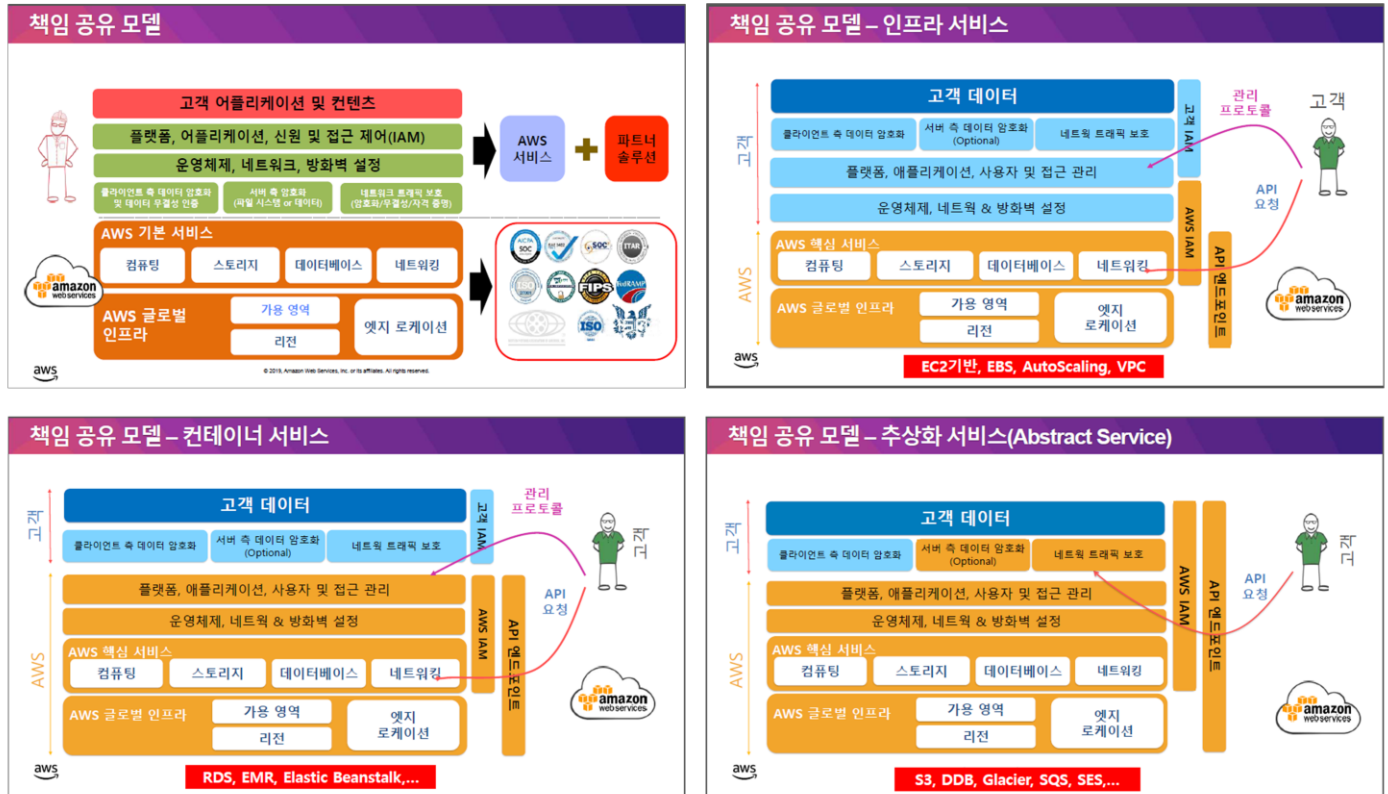


※ Check Point

- 책임공유모델의 출발: "접속 계정의 password 유노출을 CSP에서 책임질 수는 없다."

[별첨.1] 책임공유모델(Shared Responsibility Model) (2/3)

AWS의 경우, 인프라 / 컨테이너 / 추상화 서비스별 책임 영역이 상이함 (e.g. AWS EC2 서비스 - IaaS 유사)



※ Check Point

- 추상화: 중요한 특징을 찾아낸 후 간단하게 표현하는 것
 - . 추상화는 필요한 부분, 중요한 부분을 통합하여 하나로 만드는 것
 - . 대표적인 예: 스마트폰 상의 아이콘

: 추상화는 여러 가지 요소들을 하나로 통합하는 방향성을 가지고 있음.
 한 가지 문제를 여러 가지로 쪼개서 나눠보는 '문제 분할'과 반대의 개념임.
 추상화를 이용하여 핵심적인 것만을 남겨 표현하게 되면, 복잡한 내용도 한 눈에 알아볼 수 있어 이해하기 쉽다는 장점이 있음.



구분	AWS	이용자
① 규정 준수 측면	▪ 시설 ▪ 물리적 보안 ▪ 컴퓨터 인프라 ▪ 스토리지 인프라 ▪ 네트워크 인프라 ▪ 가상화 레이어 ▪ 정립된 서비스 엔드포인트 ▪ 다양한 IAM 기능	▪ 네트워크 환경설정 ▪ 시큐리티 그룹 ▪ OS 방화벽 ▪ 운영체제 ▪ 어플리케이션 ▪ 적절한 서비스 환경설정 ▪ 자격 인증 및 계정 관리
② PaaS 측면	▪ 근원 서비스 - 네트워킹, 컴퓨트, 스토리지 ▪ AWS 글로벌 인프라 ▪ AWS API 엔드포인트 ▪ 운영체제 ▪ 플랫폼/어플리케이션	▪ 고객 데이터 ▪ 방화벽 / VPC ▪ 고객 IAM(유저, 그룹, 룰, 정책) ▪ 고 가용성 ▪ 데이터 보호(전송, 대기, 백업) ▪ 확장성
③ SaaS 측면	▪ Foundational Services 근원 서비스 ▪ AWS 글로벌 인프라 ▪ AWS API 엔드포인트 ▪ 운영체제 ▪ 플랫폼/어플리케이션 ▪ 데이터 보호(대기 시 서버 측 암호화(SSE) 사용, 전송) ▪ High Availability / Scaling	▪ 고객 데이터 ▪ 데이터 보호(대기 시 클라이언트 측 암호화(CSE) 사용) ▪ AWS IAM(유저, 그룹, 룰, 정책)

※ Check Point

* 출처 : <https://aws.amazon.com/ko/compliance/shared-responsibility-model/>

* AWS의 책임

- 클라우드보안
- 클라우드 환경을 구성하는 인프라에 대한 보안을 책임짐
- 하드웨어, 소프트웨어, 네트워킹, 데이터 센터 → AWS의 서비스를 실행하기 위한 요소

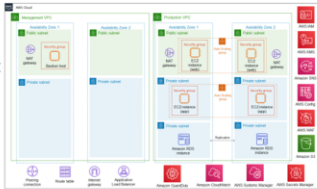
* 고객의 책임

- 클라우드에서의 보안
- 클라우드에 저장하고 연결한 것에 대한 보안을 책임짐
- 게스트 OS 관리, 고객이 인스턴스에 설치한 모든 어플리케이션 소프트웨어 혹은 유틸리티, 인스턴스별로 AWS에서 제공한 방화벽의 구성 관리 등

[별첨.2] AWS Native 서비스의 ISMS 항목과의 연계성 (1/4)

- AWS의 경우, CSP 책임 영역(예: 서울 리전 + 엣지 로케이션)에 대하여 국내외 다양한 정보보호 인증을 획득 하였음.
- **CSC 책임 영역의 경우**, 규정준수 용도로서 Quick Starts(CloudFormation 응용), Conformance Pack(Config 응용), Inspector 등을 이용하여 ISMS-P 정보보호 인증에 대응할 수 있음.

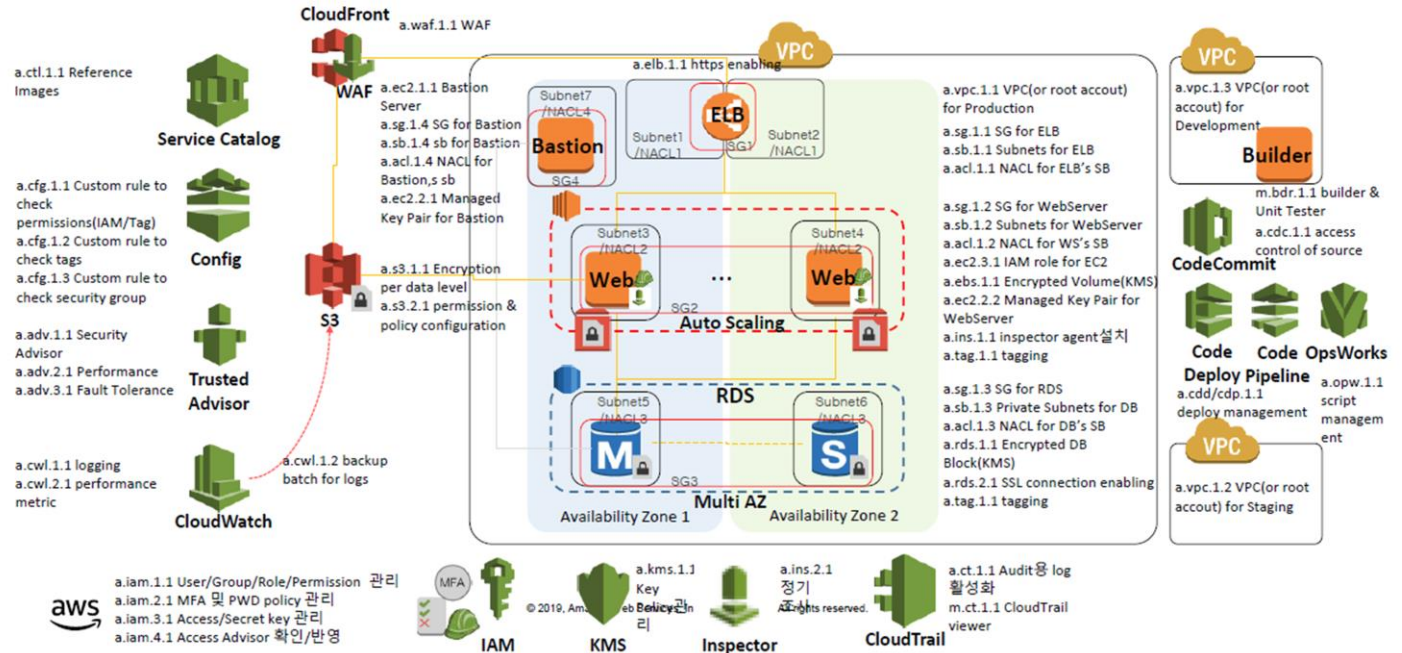
ISMSPControlMat
KR.version202011



ISMS-P 규정 준수를 위한 AWS 지원 도구



※ Check Point



※ Check Point

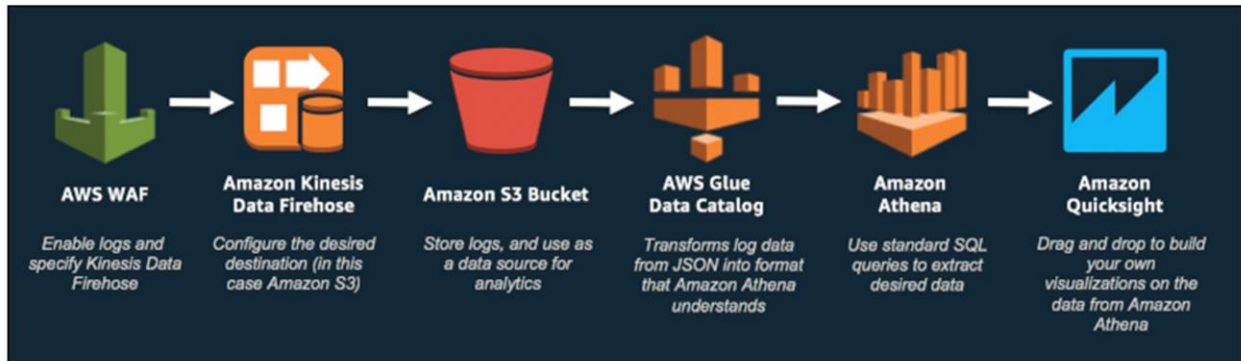
- ◆ AWS CodeDeploy
 - ◆ ISMS 8.2.3 운영환경 이관
 - 통제된 절차에 따라 이루어져야 하고 실행코드는 시험과 사용자 인수 후 실행하여야 한다.
 - ◆ 코드 배포를 완전히 자동화해 주므로 이를 사용하면 코드를 안전하고 신속하게 배포
 - ◆ AWS Management Console 또는 AWS CLI를 통해 손쉽게 애플리케이션 배포를 시작하고 해당 배포 상태를 추적
-
- ◆ AWS IAM
 - ◆ ISMS 10.1.1 접근통제 정책 수립, 10.2.1 사용자 등록 및 권한부여, 10.2.2 관리자 및 특수권한 관리, 10.2.3 접근권한 관리, 10.3.1 사용자 인증, 10.3.2 사용자 식별, 10.3.3 사용자 패스워드 관리
 - ◆ AWS 서비스와 리소스에 대한 접근을 사용자, 그룹별 등록/변경/삭제 및 통제(허용, 거부)
 - ◆ Web ID 공급자를 사용한 모바일 애플리케이션용 접근제어 관리
 - ◆ AWS CloudTrail과 연계한 감사 추적
 - ◆ 안전한 인증, 패스워드 규칙을 적용



- ◆ Amazon CloudWatch
- ◆ ISMS 11.2.3 성능 및 용량관리, 11.2.4 장애관리
- ◆ ISMS 11.6.2 로그기록 및 보존, 11.6.3 접근 및 사용 모니터링
- ◆ 기존 시스템, 애플리케이션, 사용자 지정 로그 파일을 CloudWatch 로그로 전송하여 실시간 모니터링(대시보드 활용)
- ◆ 별도 스토리지에 로그 저장 가능
- ◆ 임계치를 설정하여 알람 등 조치 적용



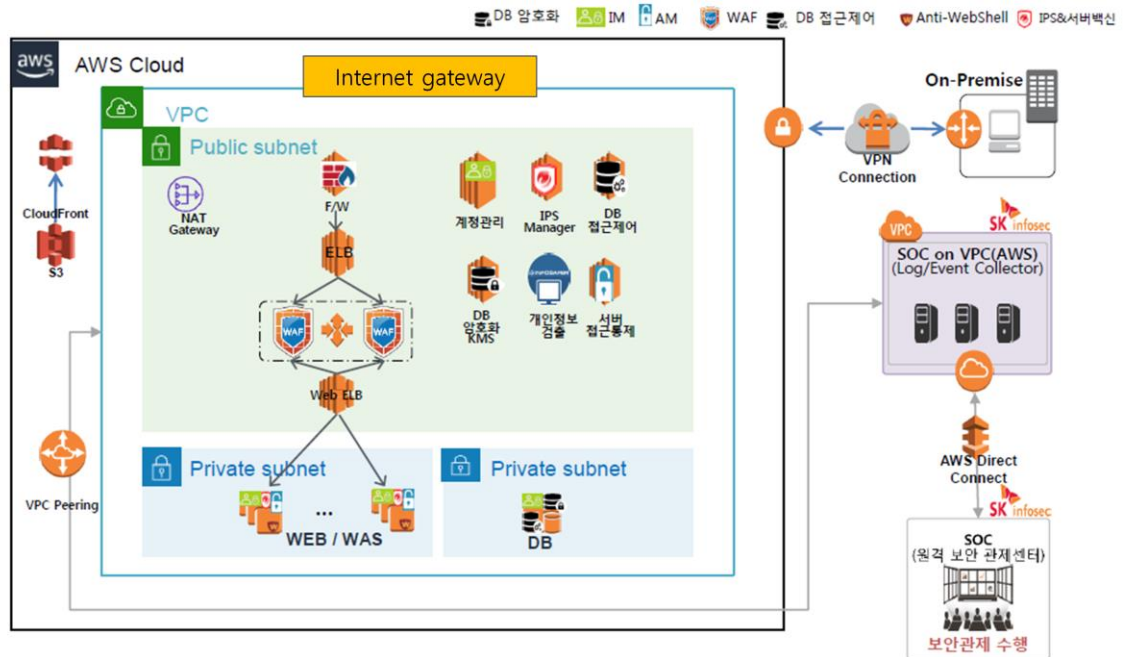
※ 참조 : AWS의 로그 활용 방안



※ Check Point

보안관리 대응 측면 중 중요한 하나는 구축한 정보보안시스템을 이용하여 보안관제를 수행하는 것 임.
아래 구성은 **대량의 out-bound traffic을 감소**시키기 위한 하나의 방안으로 **collector(수집기)의 압축, 필터링 기능을 활용**하여 필수적인 보안 이벤트만 **on-prem. 관제센터/SIEM**으로 전달하는 방식임.

- Checkpoint
 - 클라우드 구성
 - . 가상 사설 클라우드
 - . VPC간 내부 통신
 - 네트워크 구성
 - APP 구성
 - 보안서비스 구성
 - 보안관제 구성
 - . 비용 효율적 구성



[별첨.3] 클라우드 보안관제 (2/2) - 클라우드 보안운영 및 관제 고려사항

CSC(이용자)의 보안조직의 경우, 클라우드로의 APP / 서비스 이전은 **보안요건 적용 외에도** 이전에 따른 **보안솔루션 운영, 보안관제 측면에서도 심도 깊은 운영 검토**가 이루어져야 함.

구분	설명	고객관점 직접운영	고객관점 위탁운영	비고
클라우드 보안솔루션 운영 측면	• CSP/MSP의 경우, Native 솔루션 권장 ⇒ CSC는 native 솔루션의 장애 대응 어려움 발생, 既 솔루션 운영자들은 기존 환경과의 일치성 요구	O		• “직접운영”의 주체 : 고객
	• SK실더스 : 3rd party 보안솔루션 구축/운영 서비스 제공 ⇒ 既 솔루션 운영 환경 유지의 이점 확보		O	• 전제: 원격 운영
클라우드 보안관제 측면	• On-prem의 보안관제솔루션을 보안관제사 제품으로 사용할 경우, Cloud 관제로의 보안 이벤트 트래픽을 90% 감소시켜 전달할 수 있음	O		• 전제: 클라우드 상에서 보안관제 수행 결정 시
	• 원격 보안관제 기업에 관제를 위탁하는 경우, Cloud 전문 CERT 및 원격관제요원에 의한 관제 수행		O	

SK Shieldus’s Cloud 보안관제 특징

구분	설명	비고
클라우드 보안관제 수행 방안	• CERT : Cloud 전담 3명 이상 배정 • 관제 : on-premise와 분리하지 않고 관제	
클라우드 보안관제 대상 장비	• WAF : Moniterlab’s Web Insight • IPS : DeepSecurity(TrendMicro) Host IPS	• 제품 유형 증가
클라우드 보안관제 주요 업무	• 운영 : Alive-Check, Rule 관리(DeepSecurity의 경우 매달 커스커마이징 수행) ※ DeepSecurity 의 경우 Agent 단절 Check 및 Manager에 대한 Alive-Check수행 • 관제 : 침해위험 탐지 보고	

※ Check point

- CSP – MSP간의 공생관계 존재, CSP와의 협의로 MSP가 구축한 서비스들의 과금체계를 MSP가 잡고 리드하므로 작은 서비스 론칭에도 MSP는 빠질 수 없음
- CSP, MSP는 보안 서비스도 native를 고객에게 권고함 (과금 일부를 공유하므로..)
 . 당사는 3rd party solution을 구축/(원격)운영하여야 매출을 발생시킬 수 있음
 구축한 솔루션에 대한 월, 년 과금체계를 CSP와 협의하여 정하고, 일부 공유함

[별첨.4] 보안솔루션 이전 적용성 검토

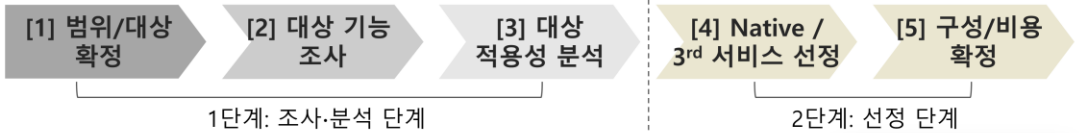
클라우드로의 보안 솔루션 마이그레이션 시 수행해야 하는 2단계 적합성 분석 절차는 아래와 같음

SUMMARY

- 보안 솔루션 적용성 분석
 - 조사·분석 단계
 - 선정(구성/비용 확정) 단계

주> On-premise 보안 솔루션 이전 / 전환은 클라우드의 다양성, 난해성을 고려하여 사업 기간을 산정합니다.

보안솔루션 이전 적합성 분석 수행 절차



구분	보안요소	기본 구축 대상	컴.플.근거 보유	AWS 보안서비스
N/W 보안	DDoS	●	●	AWS Shield Standard
	F/W	●	●	AWS ACL, Security Group
	VPN	●	●	AWS VPN
	WAF	●	●	AWS WAF
Application 보안				Advisor, AWS Inspector
				icate Manager
DB 보안				Management
Server 보안	개인정보 검색	●	●	Bastion Host
	서버접근제어	●	●	
	백신	●	●	
	패치관리	●	●	AWS Systems Manager > Patch Man
App - SaaS	파일 암호화	●	●	EBS, S3 암호화
	파일접근통제	●	●	
	CASB	●	●	
	Application G/W Security	●	●	

- ☑ [3] 대상에 대한 CSP 적용성 분석 체크 항목
- Marketplace 등재 여부
 - CSP 운용 가능 여부 (VM OS 정상 동작 여부)
 - . e.g. EC2, Azure VM
 - . 필요시 제조사-CSP간 동작 여부 테스트 수행
 - 운용정책, Lic. 이전 여부 (BYOL vs PAYG)
 - 클라우드 向 기술 지원 여부
 - : auto-scaling, Measuring, 멀티테넌시 등

- ☑ [1] 이전/전환 대상 보안 솔루션에 대한 1차 사전 선정
- ☑ [2] 1차 사전 선정 대상 보안 솔루션 기능 목록 도출을 통한 2차 사전 선정
- ☑ [4] 도출된 기능 목록 대비 대응 CSP Native 서비스 기능 매핑 조사 & 3rd party 솔루션/서비스 기능 매핑 조사 수행

Native Security Service 적용 일반화
관제: 3rd WAF, IPS 등

Check point

- 1단계: 이전 대상 확정, Market place 등재 여부, native or 3rd party 선택을 위한 1차 사전 조사 단계
- 2단계 수행 전 의사결정 필요 영역: CSP 선정, VPC 같은 클라우드 서비스 제공 영역의 개수, 자사 운영 vs. 위탁 운영, 과금 가능 범위 등
- 2단계: 운영 담당자가 결정하여야 할 최종 의사결정 단계

[별첨.5] 클라우드 보안성검토 기준 (1/3) - 보안성검토 요건 정의 (예시)

- 정보시스템 구축 시, 보안기술 참조모델(STRM)을 기반으로 한 보안성심(개발보안)요건을 충족하여 개발해야 한다.
- 범례: **Bold체** - 솔루션 구현 영역 포함 개발자 인지 필요 요건, **Bold underline체** - 개발자 인지 필요 요건

보안요건 그룹	주요 보안 요건명		보안요건 그룹	주요 보안 요건명	
접근통제	✓세션 아이들 타임아웃 적용 ✓중복 로그인, 다중 연결 세션 제한 ✓자동 로그인 제한 ✓화면보호기 비밀번호 설정 ✓화면 캡처 사용 제한 ✓중요단말기/관리용단말기 지정운용 ✓단말기 비인가 네트워크 접속 제한 ✓운영망/개발망/테스트망 분리	✓내부 업무용시스템의 외부 네트워크 접속 제한 ✓외부에서 접속 시 접근 통제 ✓무선 네트워크 통제 ✓유해사이트 접근통제 ✓시스템 설치 장소에 대한 물리적 접근통제	기밀성	✓암호키관리 ✓중요정보 표시 제한(마스킹) ✓로그인 실패 사유 상세 알림 제한	✓소스코드 난독화 적용 ✓이용자 데이터 사용 제한
			개인정보 보호	✓개인정보 파기·분리보관 ✓개인정보처리시스템 보호조치	
식별·인증	✓이용자 대체 가입 수단 제공 ✓거래 당사자 인증 ✓최초 비밀번호 변경 ✓단순 비밀번호 제한 ✓비밀번호 주기적인 변경	✓이용자 비밀번호 노출 방지 ✓비밀번호 연속 오류 대응 ✓정보시스템 접속 단말 인증 강화 ✓중요화면/페이지 인증 강화	무결성	✓파일/프로그램 배포 시스템 점검 ✓전자금융거래 프로그램 검증	✓거래정보 등에 무결성 제공
			가용성	✓장비 이중화 구성 ✓백업 및 소산 관리 ✓재해복구 대응	✓시스템 가용성 확보, 비상대책 수립 및 시행
권한 관리	✓사용자 계정 생성 원칙 준수 ✓기본 계정 사용 제한 ✓사용자 계정 공동 사용 제한 ✓계정 현행화 ✓권한부여 원칙 준수 ✓업무 및 단위별 권한에 따른 화면 통제	✓특수권한 할당 및 사용 제한 ✓DB 접근권한 통제	로그 / 추적감사	✓접속시도 오류 기록 및 알림 ✓최종 접속시간 표시 ✓전자금융거래기록 생성 및 보존 ✓인터넷 접속내용 기록 ✓거래(신용)정보 이용처리내역 기록 ✓가동·접속 기록	✓권한 변경 기록 ✓계정 권한관리 내역 로깅 ✓시스템 관리자 행위 로깅·모니터링 ✓시간 동기화 ✓로깅 정보 무결성 보증
				✓이용자 보안프로그램 설치 ✓고객단말기/스마트기기 보호 ✓표준 보안 P/G 운영 및 패치관리 ✓바이러스 백신 설치 ✓불필요한 공유 금지 ✓불필요한 서비스 불용 처리 ✓이동저장매체 통제	✓유헤트래픽 차단 ✓실시간 감시 및 대응 ✓이상금융거래 방지 ✓보안성 심의 및 취약점 점검 ✓전산자료 유출 방지 ✓보안 코딩 가이드 준수 ✓가상화/클라우드 보안
기밀성	✓표준 암호화 준수 ✓중요 정보 암호화 ✓비밀번호 암호화 ✓주요 입력 필드 암호화 ✓비밀번호 평문 하드코딩 제한	✓단말기 내 정보 암호화 ✓전송구간 암호화	보안 운영·관리 서비스		

Check point

- 기준 구성의 원칙: **S.TRM 등 일반적으로 인정받는 기준**으로 구성
- * 일반적으로 인정받는 기준: 국제표준, 로컬(국내)표준, 산업표준, 시장표준, 기업 내 표준

개인정보처리시스템 구축 시 하기 컴플라이언스와 그에 대응되는 보안성검토 요건을 만족할 수 있도록 해야 함.

보안요건 유형	개인정보의 안전성 확보조치 기준	(구) 개인정보 기술적·관리적 보호조치 기준	개발보안요건 정 의 서 기준
접근통제	제6조(접근통제) ①항 ~ ⑦항 - ⑤항, 일정시간 이상 업무처리를 하지 않는 경우 에는 자동으로 시스템 접속 차단 - ⑦항, 비밀번호 설정	제4조(접근통제) ①항 ~ ⑩항 - ⑩항, 최대 접속시간 제한 - ⑦항, 비밀번호 설정	접근통제 요건 SDSEC01 ~ 11 적용 - 자동 시스템 접속 차단 → SDSEC 11 예시
식별/인증	제6조(접근통제) ②항 - 외부에서 개인정보처리시스템 접속시 안전한 접속/인증 수단 적용 제10조(관리용 단말기의 안전조치) 1호 - 비인가 사용자의 관리용 단말기 접근 제한	제4조(접근통제) - ④항, 외부에서 접속시 안전한 인증수단 적용	식별/인증 요건 SDSEC22/23/25/26/28 - 비밀번호 설정 → SDSEC22
계정/권한관리	제5조(접근 권한의 관리) - ②항, 인사이동 발생시 접근권한 현행화 - ④항, 취급자별 사용자 계정 발급	제4조(접근통제) - ①항, 접근권한 최소 부여 - ②항, 접근권한 현행화	계정관리 요건 SDSEC17 ~ 20 적용 권한관리 요건 SDSEC29/31/32/33 적용
기밀성	제7조(개인정보의 암호화) - 암호 대상, 방법 정의, 저장·전송 시 암호화 - 암호키 운영 절차 수립	제6조(개인정보의 암호화) ①항 ~ ④항	기밀성 요건 SDSEC34/35/36/39/40/41 적용
로깅/감사추적	제5조(접근 권한의 관리) ③항 기록 3년 보관 제8조(접속기록의 보관 및 점검) - 접속기록 1년: 개인정보처리시스템 - 접속기록 2년: 고유식별·민감정보 보관 시스템 - 접속기록 반기 1회 이상 점검	제4조(접근통제) ③항 접근권한기록 5년 보관 제5조(접속기록의 위·변조방지) ①항 ~ ②항	로깅/감사추적 요건 SDSEC48~51/55~59 적용 (제외 요건 : SDSEC52 ~ 54)
개인정보보호	제13조(개인정보의 파기) - 복구 불가능한 안전한 파기 방법 제시·준용	제9조(출력·복사시 보호조치) ②항 - 개인정보의 출력·복사물 보호조치	개인정보보호 요건 SDSEC46 ~ 47 적용
무결성/가용성	제8조(접속기록의 보관 및 점검) ③항 - 개인정보취급자 접속기록의 위·변조 방지	제5조(접속기록의 위·변조방지) ③항	무결성/가용성 요건 SDSEC60/61/64~68
보안관리	제9조(악성프로그램 등 방지) - 백신 설치, 운용 요건 제10조(관리용 단말기의 안전조치) 1호 ~ 3호	제7조(악성프로그램 방지) 1호 ~ 2호 제4조(접근통제) ⑤항 2호, IP주소 등 재분석	보안관리 요건 SDSEC69~77/82/84 적용 - 안전성 확보조치 기준 6조 ①항 1호 → 실시간 감시 및 대응 (SDSEC77) - 안전성 확보조치 기준 6조 ③항 → 표준 보안관리 프로그램 설치/관리(SDSEC71) - 안전성 확보조치 기준 6조 ④항 → 보안성 검증 및 취약점 점검(SDSEC81)

※ Check Point

Cloud 보안성 검토 요건은 Cloud Infra 및 운영 환경을 반영해야 함.

※ 본문 상부 – Cloud 전용 보안 요건, 하부 – On-premise 요건에 Cloud 환경이 대폭 반영된 요건

보안요건 그룹	주요 보안 요건명
Cloud 보안	✓ Hypervisor 보안 : Inf. 등 접근통제, -계정- 최소 권한 부여, 악성코드 방지, 보안패치, SW설치통제, 주기적 로그 분석을 통한 이상징후 모니터링 수행 등 ✓ Web Mgmt. Console 접근통제 ✓ API 보안 : 호출 통제, 취약 통신방식 지양 등 ✓ 가상자원 보호 : 무결성 보증, 실행 이력 보관, 서비스별 망 분리, 테넌트 내 접근통제 적용 ✓ 데이터 완전 삭제 : 운영폐쇄 시 백업본 잔존 기간까지 고려한 클라우드 데이터 삭제 조치 ----- ✓ 전송구간 암호화 : 데이터 Cloud 이전 시, VM Migration 시 ✓ 중요 데이터 완전 삭제 : 가상 자원 회수 포함 ✓ Snapshot 이미지 백업 기반을 고려한 가용성/로깅 보안 ✓ 보안설정 : e.g. AWS 네트워크 단위 NACL, VM 단위 Security Group ✓ 백신 등 표준보안SW 설치 및 운영

※ Check Point